

EFREI PARIS

École d'ingénieurs du numérique

Rapport de Stage

Stagiaire chargé des systèmes d'information

BENDAHDHMANE Ilyan

10 novembre 2025 – 3 avril 2026

Tuteur entreprise : Mathieu Machet, Responsable Infrastructures informatiques

Tuteur pédagogique : Hassane Mimoun

Formation : INGE 2 – Majeure Cybersécurité & Cloud (4^e année du cycle ingénieur)

Diplôme visé : Diplôme d'Ingénieur de l'EFREI

Entreprise d'accueil : VINCI Concessions

1973 Boulevard de la Défense, 92000 Nanterre

Année scolaire : 2025 / 2026

Remerciements.....	4
1.Introduction	5
2.Présentation de l'entreprise, de l'équipe et du contexte de travail. Identification des acteurs du secteur et des marchés dans le domaine.....	6
A) VINCI Concessions au sein du groupe VINCI	6
B) Secteur d'activité	7
C) La DSI (Direction des Systèmes d'Information).....	9
3.Rappel du projet de stage et des objectifs principaux à atteindre.	11
A) Contexte et genèse du projet principal.....	11
B) Objectifs du projet SIEM Sentinel vers Sekoia	12
C) Missions complémentaires et leurs objectifs	13
D) Objectifs personnels	14
4.Description de l'environnement métier et technique.	14
A) Une infrastructure décentralisée et tolérante aux pannes.....	15
B) Accès au réseau et aux ressources de l'entreprise	15
C) Outils et applicatifs de la DSI	17
D) L'écosystème de sécurité	18
E) La relation DSI – filiales.....	19
5.Description des différentes étapes de l'analyse jusqu'à l'étude de solutions.	20
A) Projet SIEM	20
B) Projet MDM : de l'analyse de risque à l'étude de marché	23
C) Mini-projet GCP Mechanix : un échec formateur	25
6.Présentation de l'architecture synthétique de la réalisation matérielle et logicielle...	26
A) Architecture de collecte des logs pour le POC Sekoia	26
B) Architecture de la plateforme Sekoia	27
C) Architecture du projet GCP CCAI Platform	28
7.Eléments importants du développement et difficultés rencontrées.	30
A) Difficultés liées à la montée en compétences initiale.....	30
B) Difficultés techniques du projet SIEM	31
C) Difficultés du projet MDM.....	33
D) Une difficulté transformée en force : la curiosité comme moteur.....	33
8.Intégration, résultat des tests, comparaison avec les objectifs.....	34

A) Résultats du POC Sekoia	34
B) Résultats du projet MDM	35
C) Résultats du projet GCP CCAI.....	36
D) Résultats des missions annexes	36
E) Bilan global : comparaison avec les objectifs	36
9.Observation des pratiques managériales.....	37
A) La philosophie managériale du DSI.....	37
B) L'encadrement au sein de l'équipe infrastructure	38
C) Le recours aux prestataires externes	39
D) Enseignements personnels	40
10.Conclusion.....	40
A) Devenir du travail et développements ultérieurs	40
B) Bilan du stage	41
C) Apport et enseignement personnel	42
D) Place de ce stage dans le projet professionnel	42
11.Bibliographie	43

Remerciements

Ce stage a été une aventure incroyable et il me serait impossible de tourner cette page sans remercier les personnes qui l'ont rendue possible.

Tout d'abord, un immense merci à mon référent Xavier, qui a pris le temps de répondre mes trop nombreuses questions avec calme et pédagogie. Au-delà de sa patience, je le remercie d'avoir été à l'écoute de ce que je voulais faire. En entendant mon intérêt pour l'IAC, il a tout fait pour m'y intégrer. Et quand j'ai échoué sur le premier projet, au lieu de passer à autre chose, il m'a mis sur un deuxième, puis un troisième, ce qui m'a permis d'en comprendre les bases de son fonctionnement. Je le remercie également d'avoir réussi, malgré tout, à m'orienter vers des projets liés à la cybersécurité, en rapport avec mes études, ce qui n'était pas à l'origine, le sujet principal du pôle infrastructure.

Un grand merci à Hakim, pour les nombreux conseils, tirés de son expérience dans plusieurs domaines et entreprises. Ceux-ci me seront utiles pour mes projets futurs.

Je remercie également à Mohamed pour l'aide qu'il m'a apporté tout au long de ce stage, notamment lorsque Xavier était absent en répondant à mes questions.

Merci à Georges, Antoine et Jean-Michel, mes voisins du quotidien. Nos discussions, notamment cinématographiques, m'ont permis une plus grande ouverture d'esprit et ont rendu mes journées bien plus agréables.

Merci à Mathieu, mon tuteur de stage. Malgré un congé paternité pendant une partie de mon stage, il a toujours été disponible et prêt à répondre à mes questions quand j'en avais besoin.

Merci à Loïc, notre RSSI, pour ton accompagnement et tes conseils sur la sécurité. Tes avis m'ont été et me seront toujours très précieux.

Enfin, merci au DSI Thierry Michelland, qui a pris soin à ce que mon stage se déroule correctement. Ces nombreux échanges sur le management, l'organisation, la vision stratégique, la poésie et tant d'autres sujets m'ont permis de développer ma curiosité et de ne pas uniquement m'enfermer dans des problématiques techniques.

1.Introduction

Je réalise mon stage de novembre 2025 à avril 2026 de VINCI Concessions, pôle du groupe VINCI. Ce stage s'inscrit dans le contexte de ma formation d'Ingénieur de EFREI Paris en Master 1 dans la majeure sécurité Cloud de la filière cybersécurité et réseau. Je l'ai réalisé au sein de l'équipe infrastructure de la DSI (Direction des Systèmes d'Information).

Dans une formation informatique orientée vers la sécurité, il est précieux d'avoir une vision de l'infrastructure. Cela permet de connaître plus en détail les éléments qui composent le Système d'Information et de mieux appréhender l'origine du risque informatique. J'ai choisi de réaliser mon stage dans ce domaine car il s'inscrit pleinement dans mon projet professionnel. En effet, effectuant une formation académique en informatique, je souhaitais mettre en pratique dans une entreprise les connaissances et compétences accumulées. Rentrer dans une grande entreprise m'offrirait aussi l'accès à un grand système d'information déjà en place et la possibilité d'observer les différents mécanismes qui le font fonctionner. De plus, cela permettrait de découvrir quelles technologies sont utilisées au niveau industriel et la manière dont elles sont déployées.

J'ai été accueilli au sein de la Direction des Systèmes d'Information (DSI) de Vinci Concessions. Mon officiel tuteur de stage, Mathieu MACHET, est responsable de la direction technique de la DSI. Mais, pour des raisons opérationnelles ainsi que de cohérence avec mon parcours, c'est finalement Xavier Morand, Ingénieur systèmes et réseaux de la même équipe qui s'est occupé de moi. Le cœur d'activité de VINCI Concessions est celui de la concession d'infrastructure de transport et, dans ce cadre, la DSI est une fonction support des activités métiers de l'entreprise. J'ai trouvé qu'intervenir en soutien de fonctions métiers était très intéressant et c'est une des raisons qui m'ont fait choisir ce stage.

Issu d'une classe préparatoire scientifique, je n'ai intégré le cursus informatique qu'un an avant le début de ce stage, et n'ai été initié à la cybersécurité que quelques mois avant celui-ci. De ce fait, je n'avais pas, au moment de ma recherche de stage, de domaine de spécialisation précis à proposer au-delà de la cybersécurité au sens large. Le sujet de mon stage n'a donc pas été défini en amont : les premières semaines ont été consacrées à des missions exploratoires variées, destinées à me familiariser avec l'infrastructure, et le contexte de VINCI Concessions et à identifier le projet qui correspondrait le mieux à mes compétences en développement et aux besoins de l'équipe. Parmi ces premières missions figuraient notamment, un mini-projet d'Infrastructure as Code sur Google Cloud Platform, un travail de recensement des authentifications des filiales ayant basculé d'un Keycloak (fournisseur d'identité (IDP)) d'une fédération utilisateur en LDAP à une fédération en SAML (des protocoles d'authentifications associés au SSO (Single Sign On) du pôle de VINCI Concessions) et plusieurs petites missions similaires permettant de mieux comprendre le contexte et l'infrastructure de VINCI Concessions.

Au terme de cette phase d'exploration, d'environ trois à quatre semaines, basé majoritairement sur de la documentation, il a été décidé, en concertation avec le RSSI et l'équipe infrastructure, de m'assigner au projet de migration du SIEM (Security Information and Event Management) de Microsoft Sentinel vers Sekoia.io. Ce projet, qui constituait un enjeu majeur pour la DSI, a occupé la partie centrale et la plus conséquente de mon stage. Il m'a amené à travailler sur le transfert et l'adaptation de règles de détection, la création d'automatisations via l'orchestrateur de Sekoia, la rédaction d'un cahier des charges, la rédaction de documentation pour le wiki de l'entreprise ainsi que la réalisation d'un bilan comparatif et d'une présentation destinée aux filiales du groupe. En parallèle et à la suite du POC Sekoia, j'ai eu l'occasion de mener d'autres missions significatives : une étude de marché pour le choix d'un nouveau MDM (Mobile Device Management), une étude d'amélioration de la connexion qui se fait entre la base de données PostgreSQL et un utilisateur QGIS (un système d'information géographique (S.I.G) qui permet de recueillir, stocker, traiter, analyser puis mettre en forme des données géographiques), ainsi que la création d'un projet métier GCP (Google Cloud Platform) pour la plateforme « Contact Center AI de ViaCristais », un chatbot répondant aux questions et transférant vers le bon service quand cela est nécessaire.

Afin de rendre compte de l'ensemble de ces travaux, ce rapport est structuré en onze parties. Après cette introduction, je présenterai l'entreprise, l'équipe et le contexte de travail, puis je rappellerai le projet de stage et ses objectifs. Je décrirai ensuite l'environnement métier et technique, avant de détailler les différentes étapes d'analyse et d'étude de solutions. La sixième partie présentera l'architecture synthétique des réalisations, suivie des éléments importants du développement et des difficultés rencontrées. Je traiterai ensuite de l'intégration et des résultats des tests, puis de mes observations sur les pratiques managériales. Enfin, la conclusion dressera le bilan de ce stage et sa place dans mon projet professionnel, avant la bibliographie.

2.Présentation de l'entreprise, de l'équipe et du contexte de travail. Identification des acteurs du secteur et des marchés dans le domaine.

A) VINCI Concessions au sein du groupe VINCI

VINCI Concessions est un pôle du groupe VINCI qui vient se placer dans la partie Concession de l'activité de VINCI.

La [figure 1](#) présente l'organisation simplifiée du groupe VINCI et la position des différentes entreprises associés à ce groupe ainsi que la répartition de son chiffre

d'affaires en 2025 (source Chiffres clés métiers). Cet organigramme permet de situer VINCI Concessions au sein du groupe VINCI. Créée en 1996, VINCI Concessions est une entreprise spécialisée dans la concession à l'international, notamment dans le domaine des infrastructures de transport.

Elle représente 18 % du chiffre d'affaires du groupe et travaille avec plus de 20 000 collaborateurs (internes et prestataires) situés dans 24 pays différents, lui donnant un ancrage international important. Ce cadre m'a permis de travailler et d'échanger (à distance) avec des interlocuteurs étrangers durant mon stage, stage qui s'est déroulé entièrement à Nanterre dans les bâtiments du Groupe VINCI, l'Archipel, situés au 1973 boulevard de la Défense.

B) Secteur d'activité

1) Définition d'une concession

Si la position de VINCI Concessions au sein du groupe VINCI paraît assez évidente, le secteur d'activité de l'entreprise n'est pas toujours bien compris. En effet, après quelques échanges avec des personnes de mon entourage à propos de mon stage, le principe d'une concession n'était pas toujours bien clair. La définition d'une concession, selon le TLFI (Trésor de la Langue Française Informatisée), est un « Accord passé, pour une durée généralement limitée, entre une collectivité publique et une société privée ou un particulier, chargé d'exécuter un travail, d'assurer un service en se rémunérant par des perceptions prélevées sur les usagers ». On peut trouver, par exemple, des concessions de chemins de fer, d'aéroports, de ponts.

VINCI Concessions travaille sur des concessions à long-terme. Celles-ci sont régies par des contrats de concession. Dans le domaine des transports, celui qui « loue » l'infrastructure doit prendre en charge l'exploitation quotidienne, le développement du trafic et le financement de cette infrastructure. Le concédant est en général une autorité publique, ce qui explique les interactions entre VINCI Concessions et les différents états concernés.

2) Les différents secteurs

a) Aéroports

Si l'on vient d'expliquer plus précisément le principe de concession, il paraît important de décrire les différents secteurs d'activité dans lesquels VINCI Concessions agit, que ce soit directement ou par le biais de ses filiales. La première et la plus importante est l'activité aéroportuaire représentée par la filiale VINCI Airports. Celle-ci gère plus de 70 aéroports dans 14 pays différents. On pourrait résumer son activité comme suit :

- Conception et maîtrise d'ouvrage (choix des investissements à réaliser et conduite de chantiers),

- Développement du trafic aérien,
- Développement des activités extra-aéronautiques (amélioration de l'expérience passager via des activités ayant un rapport avec l'aéroport en tant que lieu comme la gestion des parkings ou de la location automobile).

b) Autoroutes

Si l'activité aéroportuaire représente une place très importante dans l'activité de VINCI Concessions, l'activité autoroutière n'est pas en reste. C'est par la filiale VINCI Highways et le pôle VINCI Autoroutes que sont gérées les concessions autoroutières. VINCI Autoroutes gère les autoroutes françaises, là où VINCI Highways gère des réseaux routiers à l'international dans 15 pays différents. On peut donner quelques chiffres pour illustrer l'importance de VINCI Highways à l'étranger : ce sont 441 millions de véhicules servis en 2025 pour 3500 kilomètres de réseaux routiers composés de ponts, de tunnels et d'autoroutes. Ses missions s'articulent autour de deux grands axes : le développement de concessions (en les créant de zéro ou en refondant l'infrastructure existante) l'optimisation des infrastructures en exploitation.

c) Voies ferrées et autres concessions

Une autre division de VINCI Concessions est VINCI Railways qui est un acteur spécialisé dans l'infrastructure ferroviaire. Un de ses projets les plus importants est la ligne LGV SEA Tours-Bordeaux dont la commercialisation et la maintenance sont assurées par MESEA et la maîtrise d'ouvrage par LISEA, deux filiales de VINCI Concessions.

Finalement, la dernière division en tant que telle de VINCI Concessions est VINCI Stadium qui s'occupe de l'exploitation de différents stades en France, parmi lesquels on retrouvait notamment stade de nice, le stade du MANS ou précédemment le stade de France à Saint-Denis (concessions qui vient d'être perdue par VINCI Concessions, dans laquelle j'ai pu m'y déplacer dans une phase de liquidation avec le nouveau concessionnaire « consortium du Stade de France »).

Enfin, citons d'autres concessions gérées par VINCI Concessions : de l'éclairage public, comme à Rouen, des barrages sur l'Aisne et la Meuse, avec la société BAMEO, un parking sécurisé pour poids lourd à Valenciennes ou des transports par bus en Martinique.

3) Une entreprise engagée dans les énergies renouvelables

Au-delà de ses activités historiques de concession d'infrastructures de transport, VINCI Concessions s'est engagé dans le développement des énergies renouvelables sur les emprises de ses infrastructures. Cet engagement s'inscrit dans la stratégie environnementale du groupe VINCI, qui ambitionne d'accélérer la transition énergétique des territoires.

a) SunMind : une filiale dédiée au solaire

Pour structurer cet engagement, VINCI Concessions a créé SunMind, une filiale spécialisée dans le développement, le financement, la construction et l'exploitation de centrales solaires photovoltaïques. L'idée est de valoriser les surfaces disponibles sur les infrastructures en concession (parkings d'aéroports, abords d'autoroutes, sites de maintenance ferroviaire) en y installant des centrales solaires, souvent en autoconsommation. À ce jour, les centrales solaires de VINCI Concessions génèrent un total de plus de 82 MWc de capacité, et l'ambition affichée est de dépasser 1 GWc sur l'ensemble de son réseau d'infrastructures à l'horizon 2030.

b) Quelques réalisations concrètes

Cet engagement se traduit par des projets déployés sur l'ensemble des infrastructures du groupe. On peut citer, à titre d'exemple, la centrale solaire en ombrières de l'aéroport de Lyon-Saint Exupéry d'une puissance de 20 MWc, celle de l'aéroport de Faro au Portugal couvrant 30 % des besoins électriques de l'aéroport, ou encore l'installation de 500 kWc sur un site de maintenance de la LGV SEA à Clérac exploité par MESEA. Sur le réseau routier, un système d'éclairage intelligent déployé sur l'autoroute Olympia Odos en Grèce, intégrant capteurs et intelligence artificielle, a permis de réduire la consommation énergétique à moins d'un quart de son niveau de 2020

C) La DSI (Direction des Systèmes d'Information)

Pour terminer cette présentation de l'entreprise, il me paraît important de décrire l'organisation de la DSI qui est le pôle de VINCI Concessions dans lequel j'ai réalisé mon stage.

1) Définition du rôle de la DSI

La Direction des Systèmes d'Information, ou DSI, a pour rôle d'assurer le bon fonctionnement de l'ensemble des outils informatiques de l'entreprise. Elle veille à ce que les collaborateurs disposent de moyens de travail fiables, adaptés à leurs besoins et en accord avec les objectifs de VINCI Concessions. Son action ne se limite pas à la gestion des ordinateurs ou des logiciels : elle participe aussi à l'évolution de l'entreprise en proposant des solutions utiles, en accompagnant les projets métiers et en garantissant la continuité des services informatiques.

La DSI a également une mission essentielle de protection des informations et des outils numériques. Elle définit les règles à suivre pour limiter les risques, prévenir les incidents et protéger les données de l'entreprise. Elle informe et sensibilise les utilisateurs aux bonnes pratiques, contrôle l'application des règles de sécurité et conseille les différentes directions dans leurs choix. Lorsqu'un problème ou une menace apparaît, elle doit être

capable de réagir rapidement, de mettre en place les mesures nécessaires pour limiter les conséquences et de rétablir la situation dans les meilleures conditions.

Enfin, la DSI joue un rôle d'accompagnement, de conseil et d'amélioration continue. Elle étudie les besoins des services, propose des évolutions, suit la qualité des outils mis en place et s'assure que les solutions retenues restent efficaces dans le temps. Elle intervient donc à la fois comme un support pour les utilisateurs, comme un acteur clé dans la mise en œuvre des projets de l'entreprise et comme une garantie de la fiabilité et de la sécurité du système d'information.

2) L'organisation de la DSI au sein de VINCI Concessions

L'organigramme de la [figure 2](#) présente les différents pôles de la DSI. Chaque pôle de la DSI a des objectifs que nous allons présenter maintenant :

- La **Direction** est assurée par Thierry Michelland. C'est le responsable de la partie informatique de VINCI Concessions. C'est notamment lui qui valide les orientations prises par la DSI et qui prend la responsabilité des différents choix réalisés dans le pôle informatique. En d'autres termes, il pilote la DSI.
- La **Direction des études**, avec à sa tête Christian Zinn, est composée d'une dizaine de personnes. Son rôle est de développer les applications métiers de VINCI Concessions comme SOLIS (logiciel SIRH ou système d'information de gestion des ressources humaines) ou LIANA (un progiciel de gestion intégré).
- Le **Support utilisateur**, encadré par José Jorge, aussi appelé SIEL (Support Informatique En Ligne) est le support informatique de l'entreprise. Ce pôle est en contact avec les utilisateurs quand ceux-ci ont besoin d'accès à certains logiciels, d'un dépannage informatique, de nouveau matériel. Il gère le parc informatique (ordinateurs et téléphones).
- La **Direction technique** s'occupe de l'infrastructure du système d'information. Son objectif est d'assurer le bon fonctionnement ainsi que l'évolution de l'infrastructure réseau et système du système d'information. C'est la direction qui m'a accueilli. Elle se compose de sept personnes : Mathieu Machet, mon officiel maître de stage et responsable système et réseau, Xavier Morand, ingénieur systèmes et réseaux (mon officieux maître de stage), Laurent Lecomte, également ingénieur systèmes et réseaux, Mohammed Marouan, consultant infrastructure, Antoine Albertini, expert Microsoft, George Canadas, également expert Microsoft et Hakim Ofkir, prestataire.

- Le **RSSI** (Responsable de la Sécurité des Système d'Information), Loic Barge, assisté par Oussama Sadiq, qui a pour rôle de définir et développer la politique de sécurité de l'information dans l'entreprise. Il joue un rôle de conseil pour les autres divisions de VINCI Concessions et évalue les risques liés au SI (Système d'Information).
- Le pôle **Achats / Gestion** dirigé par Karine Bondeaux. Celui-ci a pour rôle de gérer les contrats avec les différents prestataires informatiques de la DSI.

3. Rappel du projet de stage et des objectifs principaux à atteindre.

A) Contexte et genèse du projet principal

Comme évoqué en introduction, les premières semaines de mon stage ont été consacrées à des missions exploratoires variées, destinées à me familiariser avec l'environnement technique de VINCI Concessions et à identifier le projet qui correspondrait le mieux aux besoins de l'équipe. C'est au terme de cette phase d'exploration, environ trois à quatre semaines après mon arrivée, qu'il a été décidé en concertation avec le RSSI et l'équipe infrastructure de m'assigner au projet de migration du SIEM, de Microsoft Sentinel vers Sekoia.io.

Ce projet s'inscrivait dans une volonté de la DSI de réduire sa dépendance vis-à-vis de l'écosystème Microsoft. En effet, le DSI, portait depuis plusieurs années une vision claire sur ce sujet : plus une organisation consomme de produits Microsoft, plus elle devient captive de cet écosystème, chaque brique supplémentaire rendant la sortie plus difficile et plus coûteuse. De plus, VINCI Concessions a eu de manière récurrente des problèmes de facturation venant de leur part, et il était extrêmement difficile de se faire rembourser.

Au-delà de la question économique, Sentinel présentait, des limitations techniques importantes pour la DSI : l'impossibilité pour les filiales d'accéder à l'intégralité de leurs logs et de les gérer de manière autonome. Sekoia permettait de résoudre ce problème, et sans compter cela, avait beaucoup plus d'avantages que Sentinel autant au niveau technique, que relationnel ou même géographique (solution Française, excluant ainsi le Cloud Act américain).

La solution Sekoia.io avait déjà été identifiée et retenue comme candidate avant mon arrivée, mais le POC (Proof of Concept) n'avait pas encore débuté. Les premières semaines suivant mon affectation au projet ont donc été consacrées à ma montée en compétences sur le domaine du SIEM : je participais aux réunions avec notre prestataire SOC I-TRACING et l'équipe sécurité, en prenant un maximum de notes sur les très nombreux acronymes et concepts techniques qui m'étaient encore étrangers. Ce travail

de documentation et d'écoute active m'a permis, au bout de quelques semaines, de mieux comprendre les échanges techniques et d'être mieux préparé pour le lancement du POC, début décembre 2025.

B) Objectifs du projet SIEM Sentinel vers Sekoia

Les objectifs qui m'ont été assignés sur ce projet se sont construits progressivement, au fil de ma montée en compétences et de l'avancement du POC. Dans un premier temps, mes missions étaient principalement non techniques et orientées vers l'analyse budgétaire. Il s'agissait de déterminer le coût que représenterait la solution Sekoia pour VINCI Concessions et ses filiales. Sekoia proposait en effet deux modèles de tarification : l'un basé sur la volumétrie des logs ingérés, l'autre basé sur le nombre d'actifs (assets).

Pour établir ce chiffrage, j'ai dû recenser, pour chaque filiale concernée par le POC, le nombre de serveurs actifs, d'utilisateurs et de postes de travail, en m'appuyant notamment sur les rapports d'audit PingCastle (outil d'audit et de sécurisation de l'Active Directory qui permet d'évaluer le niveau de risque de l'infrastructure Windows via un rapport et des recommandations) des différentes filiales. Ce travail a abouti à la production d'un tableau comparatif des coûts entre Sentinel et les deux offres Sekoia, servant de base aux négociations commerciales.

Au fur et à mesure de l'avancée du POC, mes missions sont devenues de plus en plus techniques. Voici les principaux objectifs qui m'ont été confiés :

Le transfert et l'adaptation de règles de détection de Sentinel vers Sekoia. Il s'agissait de lire et comprendre les règles existantes écrites en KQL (Kusto Query Language) sur Sentinel, puis de les réécrire en langage SIGMA, le standard utilisé par Sekoia. Ce transfert était loin d'être une simple transposition : il nécessitait de comprendre la logique de chaque règle, de retirer les éléments spécifiques à Sentinel tels que les watchlists (des fichiers/tables externes incluant des informations complémentaires comme des Indicateurs de Compromission, des whitelists...) et d'adapter la syntaxe au format YAML de SIGMA. Chaque règle devait ensuite être testée par exemple en simulant une attaque par brute force pour une règle de ce type, ou un scan de ports via Nmap, et les résultats étaient documentés dans GitLab (fonctionnalité, temps de réponse, statut). Ce travail était réalisé en parallèle avec les équipes d'I-TRACING, prestataire SOC, qui effectuaient des tâches similaires de leur côté.

Sekoia incluait dans sa plateforme un orchestrateur SOAR (Security Orchestration, Automation and Response) permettant de déclencher des actions automatisées en réponse à des alertes. Par exemple, lorsqu'une alerte était levée sur la plateforme, un playbook pouvait automatiquement la transmettre à l'XSOAR d'I-TRACING pour traitement par le SOC.

La rédaction du cahier des charges du POC et l'exécution des tests associés.

La réalisation d'un bilan comparatif détaillé entre Sentinel et Sekoia, puis la conception d'une présentation destinée à être soutenue devant le DSI, puis devant les filiales du groupe. L'objectif de cette présentation était de convaincre les filiales, qui n'avaient pas toutes suivi VINCI Concessions dans ce changement, d'adopter Sekoia.io, ou du moins d'être un peu plus au fait de cette solution.

C) Missions complémentaires et leurs objectifs

Parallèlement au projet SIEM, et notamment à partir de la fin du POC Sekoia fin janvier 2026, d'autres missions significatives m'ont été confiées.

La première et la plus conséquente a été l'étude pour la mise en place d'un nouveau MDM (Mobile Device Management). VINCI Concessions utilisait jusqu'alors GLPI pour la gestion de son parc informatique. Si cet outil était capable de livrer des packages aux différents appareils de gérer ce parc, il se révélait très insuffisant pour la gestion des appareils mobiles : il n'offrait pas la possibilité d'accéder facilement aux informations essentielles des téléphones (nombre, assignation, caractéristiques internes), et la seule option de configuration passait par le déploiement de packages, une méthode laborieuse et inadaptée aux exigences actuelles.

Ma mission a d'abord consisté à réaliser une analyse de risque, identifiant les événements redoutés, les acteurs et sources de risque, et à calculer la criticité de chacun selon une échelle sur 16 (probabilité sur 4 multipliée par la gravité sur 4), en m'appuyant sur les conseils du RSSI, Loic Barge. Cette analyse avait pour objectif de définir précisément les fonctionnalités dont l'entreprise avait besoin. J'ai ensuite mené une étude de marché en évaluant une dizaine de solutions selon de nombreux critères : compatibilité iOS et Android en priorité, compatibilité Windows en bonus, tarification, pays d'origine, granularité de gestion, support du SSO, possibilité d'imposer les mises à jour OS, localisation d'appareil, effacement à distance (remote wipe), authentification forte sur l'écran de verrouillage, déploiement d'applications à distance, type et localisation de l'hébergement, possibilité de déploiement on-premise, dépôt de certificats, migration, prise en main à distance, et gestion de listes blanches et noires d'applications... La priorité donnée aux solutions européennes visait à éviter les problèmes de conformité liés à l'extraterritorialité des législations, notamment américaines, ainsi que les décalages horaires pouvant affecter la disponibilité du support. Certains critères ont également été définis en concertation directe avec l'équipe du support informatique (SIEL), qui serait l'utilisatrice finale de la solution.

La seconde mission complémentaire a été une étude de faisabilité autour de QGIS et PostgreSQL, d'une durée d'environ une semaine. L'objectif était d'améliorer la sécurité des connexions des utilisateurs QGIS à la base de données PostgreSQL, ceux-ci partageant jusqu'alors un même compte, ce qui constituait une mauvaise pratique de sécurité. Après avoir exploré plusieurs pistes aucune n'a permis d'implémenter un SSO

ou un MFA pour ces connexions. La recommandation finale a donc été la création de comptes PostgreSQL individuels, solution partielle car cela nécessite un travail continu de la gestion de ces comptes (création, mot de passes à réinitialiser et suppressions de ces comptes après départ de l'utilisateur) mais améliorant la traçabilité par rapport à la situation existante.

Enfin, vers la fin de mon stage, Xavier Morand, ayant noté mon intérêt pour l'Infrastructure as Code et GCP, m'a intégré au projet Contact Center AI Platform (CCAI Platform), une demande de la filiale ViaCristais visant à optimiser leur centre d'appels grâce à l'IA conversationnelle de Google, basé sur le LLM de Gemini. Ma mission consistait à créer ce projet GCP via l'usine à projets FAST Project Factory, un projet GitLab dédié à la création de projets GCP, en configurant via un fichier YAML l'ensemble des paramètres nécessaires : compte de facturation, API à activer, rôles IAM des membres de l'équipe, définition des buckets pour les tfstates, choix et configuration du VPC, création des comptes de service et paramétrage du Workload Identity Federation (WIF). Le projet était ensuite déployé via le pipeline GitLab CI/CD (2 environnements de développement, puis merge vers la production). Contrairement au mini-projet GCP du début de stage que je n'avais pas réussi à mener à bien, j'ai pu créer le projet en environnement de développement même si quelques corrections à faire sur la configuration du WIF ont été identifiées par Xavier lors de la merge request en production.

D) Objectifs personnels

Au-delà des objectifs techniques propres à chaque mission, ce stage s'inscrivait avant tout dans un objectif personnel de montée en compétences. Issu d'une classe préparatoire scientifique et n'ayant été initié à la cybersécurité que quelques mois avant mon arrivée, mon objectif principal était d'acquérir des bases solides dans les différents domaines de l'informatique d'infrastructure et de la sécurité : compréhension d'une architecture SI d'entreprise, langages et outils techniques (Terraform, SIGMA, KQL, pipelines GitLab CI/CD...), méthodologies d'analyse de risque, fonctionnement d'un SIEM et d'un SOAR, principes du SSO et de la PKI, ou encore Infrastructure as Code sur GCP. Je souhaitais également découvrir le fonctionnement d'un grand groupe international et observer les dynamiques managériales à l'œuvre au sein d'une DSI, dimension qui sera développée dans la section dédiée aux pratiques managériales.

4. Description de l'environnement métier et technique.

Cette section a pour objectif de décrire le contexte organisationnel et technique dans lequel s'inscrivent les missions de mon stage. Comprendre l'environnement du système d'information de VINCI Concessions reste indispensable pour appréhender les enjeux des projets qui m'ont été confiés, qu'il s'agisse de la migration du SIEM, de l'étude du MDM ou de la création de projets GCP.

A) Une infrastructure décentralisée et tolérante aux pannes

1) Hébergement et architecture physique

L'infrastructure serveur de VINCI Concessions est hébergée chez Equinix, dans deux datacenters distincts situés en région parisienne : PA4 à Pantin et PA6 à Aubervilliers. Le rôle d'Equinix est de fournir des salles sécurisées et l'alimentation électrique nécessaire au fonctionnement des racks. VINCI Concessions dispose de racks dédiés dans chacun de ces datacenters, les serveurs étant sa propriété.

L'architecture retenue est une architecture en miroir : les serveurs présents dans les deux sites sont actifs simultanément, et une réplication des données est assurée en temps réel entre les deux sites. Ce choix d'architecture offre une tolérance aux pannes. En cas d'incident affectant l'un des deux datacenters (incendie, coupure électrique, inondation...) l'autre site peut prendre le relais sans interruption de service. Cette conception s'inscrit dans une logique de Plan de Continuité d'Activité (PCA), essentiels pour une entreprise dont les filiales opèrent dans des fuseaux horaires différents et nécessitent une disponibilité permanente du système d'information.

2) Virtualisation et stockage

Pour déployer et gérer ses machines virtuelles, VINCI Concessions utilise Proxmox comme hyperviseur. Les hyperviseurs sont des serveurs physiques répartis dans les deux salles serveurs PA4 et PA6. Ces hyperviseurs ne gèrent pas directement le stockage : celui-ci est assuré par des machines dédiées dont le système de fichiers repose sur ZFS (un système de fichiers avancé offrant des fonctionnalités de compression, de déduplication de fusion de matériel de stockage et de snapshots). Les hyperviseurs accèdent à ce stockage via le réseau.

Il est important de noter que la capacité physique des racks est limitée. Cette contrainte d'espace influe directement sur les choix d'architecture : lorsqu'un projet nécessite un volume de stockage ou de calcul important, comme c'est le cas pour un SIEM qui doit ingérer et conserver de grands volumes de logs, une solution on-premise est exclue au profit d'une solution hébergée. En revanche, pour des projets à faible empreinte comme un MDM, le déploiement on-premise reste envisageable et a d'ailleurs été pris en compte dans l'étude de marché réalisée.

B) Accès au réseau et aux ressources de l'entreprise

1) Contexte particulier de l'Archipel

Depuis octobre 2021, l'ensemble du groupe VINCI est installé dans les locaux de l'Archipel, à Nanterre, au 1973 boulevard de la Défense. Cette centralisation visait à réunir les différents pôles du groupe afin de faciliter les synergies. Cependant, les différents pôles de VINCI restent des structures autonomes sur le plan informatique, VINCI

Concessions est en quelque sorte cliente de l'infrastructure réseau du bâtiment : les bornes WiFi, les proxys de sortie internet et l'infrastructure réseau locale sont gérés par les équipes techniques de l'Archipel, et non par la DSI de VINCI Concessions.

2) Authentification réseau et accès VPN

Pour se connecter au réseau au sein de l'Archipel, les collaborateurs de VINCI Concessions utilisent le WiFi uniVINCI, un réseau commun à l'ensemble du groupe VINCI. L'authentification sur ce réseau repose sur le protocole WPA2-Entreprise avec un serveur RADIUS. Ce WiFi ne donne cependant accès qu'à internet : il ne permet pas d'atteindre directement les ressources internes de VINCI Concessions hébergées dans les datacenters PA4 et PA6.

Pour accéder à ces ressources, c'est la solution du VPN permanent OpenVPN qui a été mise en place. Dès le démarrage de l'ordinateur, celui-ci se connecte automatiquement au VPN de VINCI Concessions en s'authentifiant via un certificat machine. Ce mécanisme est transparent pour l'utilisateur et lui donne accès à l'intégralité des ressources internes comme s'il était directement connecté au réseau de l'entreprise.

3) Authentification applicative : SSO et MFA

Au-delà de l'accès au réseau, une seconde couche d'authentification est nécessaire pour accéder aux applications de l'entreprise. VINCI Concessions utilise un SSO (Single Sign-On) qui permet à un utilisateur de ne s'authentifier qu'une seule fois pour accéder pour une durée déterminée à l'ensemble des applications web internes : messagerie, espace de stockage Nextcloud, GLPI, GitLab, et d'autres.

Le fournisseur d'identité (IdP) utilisé est Keycloak, un logiciel libre distribué sous licence Apache 2.0 et chapeauté par Red Hat. Keycloak centralise l'authentification et transmet les informations d'identité aux différents fournisseurs de services (SP) via le protocole SAML (Security Assertion Markup Language) ou OpenIdConnect. Le processus se déroule de la manière suivante : lorsqu'un utilisateur tente d'accéder à une application web, celle-ci le redirige vers la page de connexion Keycloak. L'utilisateur s'authentifie, puis Keycloak génère un jeton qui est renvoyé à l'application, validant ainsi la connexion. Pour les applications suivantes, l'utilisateur est automatiquement authentifié grâce à ce jeton.

Pour renforcer la sécurité de cette authentification, le SSO est couplé à un MFA (Multi-Factor Authentication, ou authentification à facteurs multiples). L'utilisateur doit fournir, en plus de son mot de passe, un mot de passe à usage unique généré par une application dédiée, WinAuth, installée par défaut directement sur les postes de travail Windows, ce qui simplifie l'expérience utilisateur en évitant de recourir systématiquement à un téléphone. Pour les collaborateurs souhaitant disposer d'un second facteur sur leur téléphone, cela était également possible.

Ma mission de recensement des filiales ayant basculé de LDAP vers SAML, réalisée durant les premières semaines de mon stage, s'inscrivait directement dans ce contexte d'authentification. Il s'agissait d'aller chercher l'information pour chaque filiale sur quel annuaire de confiance se basait keycloak pour l'authentification : l'Active Directory (requêté via le protocole LDAP) ou l'Entra ID (requêté via le protocole SAML), afin d'avoir une vision claire du niveau de déploiement de l'authentification unique au sein du groupe.

C) Outils et applicatifs de la DSI

1) GitLab : pierre angulaire de la traçabilité et de l'automatisation

GitLab est une forge logicielle et plateforme complète de DevSecOps basée sur Git qui centralise la gestion du code source, l'automatisation de l'intégration et du déploiement continus (CI/CD), ainsi que le suivi de projet. Il occupe une place centrale dans le fonctionnement de la DSI de VINCI Concessions. Bien au-delà d'un simple outil de versioning de code, il est utilisé comme plateforme de référence pour plusieurs usages.

Tout d'abord, GitLab sert de référentiel de traçabilité pour l'ensemble des modifications apportées à l'infrastructure. Cette partie se fait via une section appelé « Exploitation-courante ». La DSI applique une règle stricte : chaque changement, qu'il s'agisse d'une modification de configuration, d'une mise à jour de fédération LDAP, d'un ajustement réseau ou d'un déploiement, doit être documenté et référencé dans GitLab. Cette exigence de traçabilité, portée personnellement par le DSI, permet de conserver un historique complet de l'évolution du système d'information.

Ensuite, GitLab est l'outil de CI/CD (Continuous Integration / Continuous Deployment) de l'équipe. C'est par ses pipelines que sont déployés les projets d'Infrastructure as Code, notamment les projets GCP via l'usine à projets FAST Project Factory. Le principe de cette usine à projets est le suivant : l'ingénieur remplit un fichier de configuration au format YAML décrivant les paramètres du projet GCP souhaité (compte de facturation, API à activer, rôles IAM, buckets pour les tfstates, configuration du VPC, comptes de service et WIF (Workload Identity Federation)), puis soumet ce fichier via la pipeline GitLab. Celle-ci passe par plusieurs étapes (développement numéro 1, merge request, développement numéro 2, merge request puis production) et crée automatiquement le projet sur la plateforme GCP avec l'ensemble des paramètres spécifiés via le langage Terraform. C'est par ce mécanisme que j'ai créé le projet CCAI Platform pour ViaCristais.

Enfin, GitLab était l'outil dans lequel je documentais l'ensemble de mes travaux sur le projet SIEM : les paramètres des règles de détection transférées de Sentinel vers Sekoia, les résultats des tests et les migrations réalisées.

2) GLPI : gestion du parc et des demandes

GLPI (Gestionnaire Libre de Parc Informatique) est un logiciel libre français de gestion des services informatiques. Au sein de VINCI Concessions, il remplit deux fonctions

principales : la gestion du parc informatique (inventaire des postes, suivi des équipements) et la gestion des tickets informatiques via le support utilisateur SIEL. C'est par GLPI que les collaborateurs formulent leurs demandes au support : installation de logiciels, accès à des ressources, dépannage, demande de matériel... Il est proposé non seulement aux personnes du siège mais aussi aux filiales, ce qui en fait un service de l'entreprise assez important et difficile à gérer compte tenu de la diversité des fuseaux horaires.

Toutefois, comme évoqué dans la section précédente, les capacités de GLPI en matière de gestion des appareils mobiles se sont révélées insuffisantes, ce qui a motivé l'étude de marché qui a été menée pour le choix d'un nouveau MDM.

3) Autres outils utilisés

Au quotidien, j'utilisais également un certain nombre d'autres outils : Visual Studio Code comme éditeur de code pour l'écriture de fichiers Terraform, YAML ou SIGMA, VirtualBox pour la création de machines virtuelles de test, notamment lors de la validation des règles de détection Sekoia (simulation d'attaques par brute force, scans de ports...), Microsoft Teams et Outlook pour la communication et la planification.

D) L'écosystème de sécurité

1) Organisation de la supervision de sécurité

La supervision de la sécurité du système d'information de VINCI Concessions repose sur plusieurs briques complémentaires, impliquant à la fois des ressources internes et des prestataires externes.

Au niveau de VINCI Concessions, la supervision opérationnelle de la sécurité est (jusqu'à la mise en place de Sekoia), assurée par le SIEM Microsoft Sentinel, couplé au prestataire SOC I-TRACING. I-TRACING exploite Sentinel pour la détection des incidents, et utilise en complément l'orchestrateur XSOAR de Palo Alto pour l'automatisation des réponses aux alertes. La protection des postes de travail est assurée par l'EDR (Endpoint Detection and Response) Cortex, également édité par Palo Alto Networks, permettant une détection avancée des menaces sur les terminaux. Contrairement à un simple antivirus, un EDR ne se contente pas d'effectuer de la détection par signature, mais permet une analyse comportementale.

Enfin, les audits de sécurité de l'Active Directory sont réalisés à l'aide de PingCastle par Oussama Sadiq, consultant externe d'Accenture rattaché au RSSI. PingCastle est un outil d'audit spécifiquement conçu pour évaluer la sécurité des environnements Microsoft Active Directory. Il analyse l'architecture de l'AD pour y détecter les vulnérabilités, les erreurs de configuration et les mauvaises pratiques : comptes d'anciens employés toujours actifs, droits d'administration excessifs, mots de passe trop faibles, objets obsolètes. L'outil génère un rapport de santé attribuant un score de risque selon plusieurs

catégories (comptes à privilèges, relations de confiance, objets obsolètes, anomalies) et fournit pour chaque problème identifié une explication du risque associé ainsi que des recommandations de remédiation. Développé en France par Vincent Le Toux, PingCastle est devenu un standard dans le domaine de l'audit Active Directory. C'est à partir des rapports PingCastle des différentes filiales que j'ai pu extraire les données nécessaires au chiffrage du projet de migration SIEM : nombre de serveurs actifs, nombre de comptes utilisateurs et nombre de postes de travail.

2) Un périmètre conséquent

Pour donner un ordre de grandeur du périmètre supervisé du SOC, cela représente environ 8 000 comptes utilisateurs, 7 000 postes de travail et 1 000 serveurs. Ces chiffres permettent de comprendre l'ampleur des enjeux liés à la migration du SIEM : le volume de logs généré par un tel parc est considérable, et le modèle de tarification choisi a un impact budgétaire direct et significatif.

E) La relation DSI – filiales

La DSI de VINCI Concessions n'est pas un service informatique centralisé gérant uniformément l'ensemble des filiales. La réalité est plus nuancée et fonctionne au cas par cas, ce qui constitue une particularité importante du contexte de travail.

Certains services sont gérés de manière centralisée par la DSI pour l'ensemble des filiales : c'est le cas notamment du VPN et du WiFi, qui sont des briques d'infrastructure nécessitant une cohérence globale. D'autres services, comme le SIEM, sont gérés par la DSI pour une partie des filiales seulement : lors du projet de migration vers Sekoia, seules certaines filiales avaient suivi VINCI Concessions dans ce changement, les autres gérant leur supervision de sécurité de manière indépendante, mais toujours avec I-TRACING comme prestataire SOC. D'autres services encore sont entièrement gérés au niveau de chaque filiale.

Cette organisation décentralisée explique pourquoi la segmentation par filiale était un critère si important dans le choix du nouveau SIEM. Sentinel ne permettait pas cette segmentation, empêchant les filiales de consulter uniquement leurs propres événements. Sekoia, avec sa notion de communautés et son isolation complète des données entre communautés, répondait directement à ce besoin.

Les échanges entre la DSI centrale et les filiales se font au quotidien via les tickets GLPI, les réunions, les mails et la messagerie instantanée. Cette dimension d'interface avec des interlocuteurs variés, parfois internationaux et dans des fuseaux horaires différents, a constitué un aspect formateur de mon stage.

5. Description des différentes étapes de l'analyse jusqu'à l'étude de solutions.

Cette section présente la démarche analytique suivie pour chacun des projets de mon stage, depuis l'identification des problématiques jusqu'à l'évaluation des solutions. Nous commencerons par le projet principal, la migration du SIEM, avant de traiter l'étude MDM et le premier mini-projet GCP qui, bien qu'il se soit soldé par un échec, a constitué une étape d'apprentissage importante.

A) Projet SIEM

1) Identification des problématiques de Sentinel

La décision de migrer le SIEM avait été prise avant mon arrivée. Sekoia.io avait déjà été identifiée comme la solution cible. Néanmoins, au cours des premières semaines de mon affectation au projet, j'ai pu comprendre en profondeur les raisons de cette décision, à travers les réunions avec I-TRACING et les échanges avec le RSSI et le DSI. Les limitations de Microsoft Sentinel qui motivaient cette migration étaient nombreuses.

Sur le plan de la gestion des logs :

- Sur le plan de l'architecture, la gestion des logs dans un contexte multi-tenants (architecture où une seule instance de l'infrastructure sert plusieurs clients (appelés tenants), tout en garantissant que les données et les configurations de chaque organisation restent totalement isolées les unes des autres) était particulièrement difficile, et il n'existait aucune possibilité de segmentation par filiale : les différentes entités de VINCI Concessions ne pouvaient pas consulter uniquement leurs propres événements. Le siège, VINCI Concession, afin d'éviter que tout le monde ait accès aux logs de tout le monde a donc choisi de prendre en charge la gestion de ces logs, ayant comme conséquence que les filiales n'avaient plus accès à leurs logs.
- La difficulté d'ajout de nouvelle source de données (exemple serveur M365) car les logs devaient avoir un format spécifique avant leur arrivée sur la plateforme
- Sentinel fonctionnait avec un système mixte de logs « chauds » et « froids » sur trois mois, les recherches sur les logs froids étant facturées en supplément, ce qui ajoutait une couche d'incertitude sur la tenue des comptes.
- Les requêtes ne pouvaient être effectuées que sur une seule table à la fois et d'une unique manière, en KQL (Kusto Query Language), un langage à la syntaxe complexe et verbeuse développé par Microsoft.
- Enfin, sur le plan de l'outillage, Sentinel ne disposait de catalogue de règles de détection prédéfinies et d'IOC, ce qui avait comme conséquence pour les règles de détection que

chaque règle devait être créée manuellement et pour les IOC, l'import d'un catalogue externe (celui de Sekoia.io) impliquant des levés d'alerte retardés.

Au-delà de ces limitations techniques, la décision s'inscrivait dans une démarche plus globale de la DSI visant à réduire la dépendance à Microsoft et à privilégier, autant que possible, des solutions ouvertes ou souveraines. Cette philosophie se retrouvait d'ailleurs dans d'autres choix de la DSI, comme l'utilisation de Keycloak (open source) pour le SSO ou de Proxmox pour la virtualisation.

2) Critères d'évaluation de Sekoia

Les critères ayant conduit au choix de Sekoia dépassaient largement la seule comparaison technique et fonctionnelle. Un premier axe majeur était celui de la souveraineté numérique. Sekoia est une société française, dont les équipes sont situées en Europe et qui dispose d'un support dédié en français. Les données sont hébergées en Europe par un hébergeur français (OVH), ce qui préserve l'entreprise de l'exposition aux lois extraterritoriales, notamment le Cloud Act américain. La solution disposait par ailleurs des certifications ISO 27001 et PCI-DSS niveau 1, gages de sérieux en matière de sécurité de l'information.

Sur le plan fonctionnel, l'analyse comparative que j'ai rédigée pendant le POC, destinée à justifier la décision auprès des filiales et du groupe VINCI, a mis en évidence de manière concrète les avantages de Sekoia sur sept axes :

- La segmentation par filiale avec la notion de communautés fournissant une isolation complète des données, permettant aux différentes filiales de pouvoir consulter leurs logs.
- La vue et la gestion des événements : tous les logs sont en logs chauds, sans surcoût pour les consulter, facilitant la facturation.
- Les requêtes se font sur l'ensemble des événements et ce, via différentes manières : SOL (langage développé par Sekoia, très proche du KQL), en cliquant directement sur les valeurs des champs que l'on veut garder/retirer ou encore via une barre de recherche en Events Query Language), la ou Sentinel ne proposait que le KQL.
- Le déploiement des sources : catalogue de sources intégrées avec analyse automatique de format de logs, particulièrement pertinent dans le contexte hétérogène de VINCI Concessions. Plus besoin de formater les logs en amont
- Orchestrateur intégré : action sur les alertes levés, créables en mode puzzle scratch ou en JSON, la ou sur Sentinel, il fallait utiliser une solution externe (XSOAR de Palo Alto)
- Création de règles de détection avec le langage SIGMA, un standard open source en format YAML, dédié à la création de règles de détection, ce qui n'est pas le cas du KQL, dédié aux requêtes de bases de données, bien plus long et complexe à lire, et a

implémenter pour les règles de détection (même si de manière équivalente Sekoia proposait le langage SOL).

- Le catalogue intégré et maintenu à jour d'indicateurs de compromission (IOC) et de règles de détection, réduisant le temps de levé d'alerte basé sur des IOC, et réduisant la charge de travail due à la création manuelle de règles de détection.

3) Analyse budgétaire : un travail itératif et complexe

L'analyse budgétaire a constitué l'une de mes premières contributions concrètes au projet et s'est révélée être un exercice bien plus complexe qu'initialement prévu. Sekoia proposait deux modèles de tarification : l'un basé sur le nombre d'actifs (assets), l'autre sur la volumétrie des logs ingérés. ([figure 3](#) pour la facturation de Sekoia et [figure 4](#) pour celle de Sentinel)

Le modèle à l'asset définissait un asset comme le maximum entre le nombre d'utilisateurs ou de postes de travail, auquel s'ajoutait le nombre de serveurs physiques ou virtuels. C'est ce modèle qui a été étudié en premier, car il offrait une prévisibilité budgétaire que la volumétrie ne permettait pas. Pour chiffrer cette offre, j'ai été chargé de recenser le nombre d'actifs pour chacune des huit filiales concernées par le POC. J'ai extrait ces données des rapports d'audit PingCastle des différentes filiales, qui référençaient le nombre de serveurs actifs, de comptes utilisateurs et de postes de travail. J'ai ensuite produit un tableau Excel rassemblant ces données et calculant le coût total de l'offre à l'asset.

Le résultat de ce premier chiffrage a révélé un prix presque deux fois supérieur à celui payé pour Sentinel. Cette donnée aurait pu constituer un frein rédhibitoire, mais le DSI n'y était pas catégoriquement opposé. L'accumulation de problèmes avec Microsoft comme les nombreuses erreurs de facturation, la logique du « tout en un » imposant des fonctionnalités non désirées, dépendance croissante... avaient créé une forte volonté d'éloignement de ses solutions. C'est d'ailleurs à ce moment qu'il m'a été demandé de rédiger le document comparatif Sentinel versus Sekoia, afin de disposer d'une analyse objective permettant de déterminer si les avantages fonctionnels de Sekoia justifiaient un surcoût.

Le DSI a d'abord exploré des pistes de réduction du coût. Il a envisagé de remplacer l'orchestrateur, XSOAR d'I-TRACING par l'orchestrateur intégré de Sekoia, ce qui aurait pu supprimer une partie de dépense pour ce prestataire. Cependant, I-TRACING a refusé cette option : XSOAR était leur outil d'expertise, utilisé pour l'ensemble de leurs clients, et ils n'étaient pas disposés à en changer pour un seul compte. L'hypothèse d'internaliser le SOC a également été étudiée, mais elle se révélait plus coûteuse et moins fiable que la prestation d'I-TRACING.

C'est lors d'une réunion financière rassemblant le DSI, la responsable du pôle Achats/Gestion, le RSSI, le responsable de la direction technique, Xavier Morand et moi-

même, qu'une nouvelle perspective est apparue : le modèle de tarification à la volumétrie. Le prix au gigaoctet de logs proposé par Sekoia durant cette réunion était, en première analyse, environ trois fois moins cher que celui payé à Sentinel. Ce résultat semblait trop beau pour être vrai, et, après analyse s'est effectivement avéré nécessaire de le nuancer.

Il s'est avéré, après quelques investigations que les logs Sentinel étaient moins volumineux que leur équivalentes Sekoia. Cela était dû au fait que dans Sentinel uniquement la valeur du couple clé/valeur est compté dans la facturation contrairement à Sekoia qui facture l'ensemble clé + valeur.

Il a donc fallu déterminer un coefficient de conversion entre le volume de logs Sekoia et le volume de logs Sentinel. Après calculs et analyses, ce coefficient a permis de ramener le ratio de prix d'un facteur trois à un facteur un et demi environ en faveur de Sekoia. Restant malgré tout moins cher que Sentinel, le modèle à la volumétrie a donc finalement été retenu pour la majorité des filiales. J'ai par ailleurs posé, lors de la réunion, la question de la possibilité de coupler les deux modèles de tarification pour différentes filiales au sein de la même plateforme, ce qui s'est avéré possible. Cette flexibilité a permis d'identifier que pour quelques rares filiales dont la consommation de logs était disproportionnée par rapport à leur taille, le modèle à l'asset restait plus avantageux. Le risque d'une explosion ponctuelle du volume de logs, pouvant entraîner un dépassement du forfait, a été accepté comme il l'était déjà avec Sentinel.

B) Projet MDM : de l'analyse de risque à l'étude de marché

1) Analyse de risque selon la méthodologie EBIOS

L'étude pour le choix d'un nouveau MDM a débuté par une analyse de risque, réalisée en m'appuyant sur la méthodologie EBIOS (Expression des Besoins et Identification des Objectifs de Sécurité), sur les conseils de Xavier Morand et du RSSI Loïc Barge. L'objectif de cette analyse était de formaliser les événements redoutés liés à la gestion des appareils mobiles, d'en identifier les acteurs et les sources, et de calculer la criticité de chacun afin de déduire les fonctionnalités indispensables que devrait offrir la solution MDM.

La criticité était évaluée sur une échelle de 20, résultant du produit de la probabilité (échelle de 1 à 4) par la gravité (échelle de 1 à 4). L'objectif d'une échelle à chiffre paire est d'éviter la facilité du choix du milieu (si l'on avait choisi un chiffre impair comme 5, la majorité des notes auraient été à 3), conseils qui m'a d'ailleurs été donné par Loïc. Parmi les événements redoutés identifiés, on peut citer, à titre d'exemple, la perte ou le vol d'un téléphone professionnel non verrouillé contenant des données sensibles de l'entreprise (probabilité élevée, gravité très grave, criticité critique), l'installation d'une application malveillante par un utilisateur sur un appareil non supervisé (probabilité moyenne, gravité grave, criticité importante), ou encore l'impossibilité de mettre à jour le

système d'exploitation d'un appareil à distance en cas de vulnérabilité critique (probabilité probable, gravité grave, criticité importante).

Cette analyse de risque a directement orienté la définition des fonctionnalités requises pour le MDM. Un événement comme la perte d'un appareil non verrouillé justifiait les fonctionnalités de remote wipe (effacement à distance), de localisation d'appareil et d'authentification forte imposée sur l'écran de verrouillage. Le risque lié aux applications malveillantes justifiait le déploiement d'applications à distance et la gestion de listes blanches et noires. Le risque lié aux mises à jour justifiait la capacité d'imposer les mises à jour OS via le MDM...

2) Définition des critères d'évaluation

À partir de l'analyse de risque et en concertation directe avec l'équipe du support informatique (SIEL), qui serait l'utilisatrice finale de la solution, j'ai formalisé une grille de critères d'évaluation. La priorité était donnée à la compatibilité iOS et Android, la compatibilité Windows étant un bonus appréciable mais non indispensable puisque GLPI assurait déjà une gestion suffisante du parc Windows.

Les critères retenus couvraient plusieurs dimensions. Sur le plan fonctionnel : profondeur de la granularité de gestion, gestion des groupes, mode kiosque, VPN par application, prise en main à distance (remote shell), déploiement d'applications à distance, imposition des mises à jour OS, localisation d'appareil, effacement à distance, authentification forte sur l'écran de verrouillage, dépôt de certificats dans le terminal, listes blanches et noires d'applications, et inventaire d'applications et d'autres encore. Sur le plan de la compatibilité avec l'existant : support du SSO via SAML ou OpenID Connect (OAuth 2.0) pour l'authentification Keycloak, et la facilité de migration dans le cas où l'on souhaiterait changer de solution. Sur le plan de l'hébergement et de la conformité : type d'hébergement (SaaS ou on-premise), fournisseur d'hébergement (AWS, GCP, AZURE...) localisation des données, pays d'origine de l'éditeur avec une préférence pour les solutions européennes afin d'éviter les problèmes de conformité liés à l'extraterritorialité des législations et les décalages horaires affectant la disponibilité du support. Enfin, sur le plan économique : la tarification par appareil.

3) Étude de marché et filtrage progressif

L'étude de marché a commencé par un recensement large d'une dizaine à une quinzaine de solutions MDM disponibles sur le marché. Pour chaque solution, j'ai d'abord consulté la documentation technique afin de renseigner les critères de ma grille d'évaluation. J'ai ensuite contacté chaque éditeur pour confirmer les informations collectées et en profitais pour planifier une réunion de présentation de leur solution.

Un premier filtrage a permis d'éliminer les solutions présentant des points bloquants rédhibitoires. Les critères éliminatoires étaient principalement l'absence de support du SSO via SAML ou OpenID Connect (nécessaire pour l'intégration avec Keycloak),

l'absence de remote wipe, ou l'impossibilité d'imposer les mises à jour OS à distance. Ce filtrage a ramené le nombre de solutions à neuf : Miradore, Matrix42 UEM, Baramundi, Hexnode, Fleet (FleetDM), Scalefusion, ManageEngine MDM Plus, Microsoft Intune et SOTI.

Un second tour d'analyse plus approfondi, incluant les retours des présentations organisées avec cinq éditeurs (Matrix42, Hexnode, Fleet, ManageEngine et SOTI), a permis de resserrer encore la sélection. Lors de ces démonstrations, l'attention portait principalement sur l'organisation de la plateforme et sa simplicité d'utilisation, la majorité des informations fonctionnelles ayant déjà été collectées dans la documentation. Au moment de la rédaction de ce rapport, l'étude est toujours en cours. Certaines présentations planifiées ne s'étant pas encore déroulées, la dernière (Matrix42) étant prévue le 2 avril 2026, soit la veille de mon départ. Deux solutions se distinguent néanmoins : Fleet, pour son caractère open source même si quelques fonctionnalités comme le wipe et la localisation sur Android sont annoncées très prochainement, et ManageEngine, pour sa tarification extrêmement compétitive, sous réserve de la présentation encore à venir.

C) Mini-projet GCP Mechanix : un échec formateur

Bien que le mini-projet GCP réalisé en début de stage ne relève pas directement de l'analyse de solutions, il mérite d'être mentionné ici car il constitue une étape d'analyse à part entière, celle de mes propres limites techniques à ce stade du stage, et permet de mettre en perspective la meilleure prise en main du projet GCP CCAI réalisé ultérieurement.

Le ticket initial demandait la création d'une machine virtuelle sur Google Cloud Platform pour des besoins de calcul. Le travail devait être réalisé via la chaîne CI/CD de GitLab, en écrivant l'infrastructure en Terraform. Après avoir étudié la documentation de GCP, du langage Terraform et du fonctionnement des pipelines CI/CD, j'ai tenté de réaliser ce projet. L'échec n'est pas venu de la partie développement Terraform à proprement parler, mais de mon incapacité, à ce moment du stage, à appréhender l'écosystème GitLab dans sa globalité. Les notions de branches, de développement et de production, de pipelines, de merge requests... Tout cela m'étaient totalement étrangères. Je ne comprenais pas la différence entre le projet métier GCP et le projet GitLab qui le portait, ni le lien entre ces deux plateformes. J'étais en quelque sorte « noyé » par cette masse d'informations.

Cet échec, assumé et analysé avec mon référent, a néanmoins été productif. Il m'a permis de me former aux bases de Terraform et de commencer à comprendre, même partiellement, les principes de l'Infrastructure as Code et des chaînes CI/CD. Ces acquis, consolidés au fil des semaines suivantes par l'observation du travail de l'équipe du projet Sparing Partner (un autre projet IAC), et la lecture de documentation, ont directement contribué à la compréhension de ce monde qui m'était inconnu et à la création du projet

GCP CCAI en fin de stage, où j'ai pu créer le projet métier, en ne nécessitant que quelques corrections mineures sur la configuration du WIF (Workload Identity Federation) lors de la merge request en production.

6. Présentation de l'architecture synthétique de la réalisation matérielle et logicielle

Cette section présente de manière synthétique les architectures mises en œuvre dans les différentes réalisations de mon stage.

A) Architecture de collecte des logs pour le POC Sekoia

1) Architecture existante sous Sentinel

L'architecture de collecte des logs reposait sur deux concentrateurs existants :

- vcosoclog-1 pour les serveurs Linux (exemple pare-feu Palo Alto) utilisant Logstash (protocole dédié) pour récupérer les logs et les transformer. L'agent AMA (Azure Monitor Agent installé sur le serveur) s'occupait ensuite de les envoyer vers Azure Log Analytics, le puits de logs de Microsoft Sentinel.
- vcosoclog-2, pour les serveurs Windows (par exemple Active Directory, Microsoft 365). Les machines générant des logs utilisent Windows Event Forwarding pour envoyer leurs logs vers ce concentrateur. Windows Event Collector était ensuite utilisé pour réceptionner et centraliser les logs envoyés par le WEF. La dernière étape était l'agent AMA (Azure Monitor Agent), qui récupère les logs regroupés par le WEC et les expédie vers Azure Log Analytics.

Ces concentrateurs envoyaient donc leurs logs vers Log Analytics, le puits de logs de Sentinel.

Entre les concentrateurs 1 et 2 et Log Analytics, un filtre avait été configuré. Ce filtre répartissait les logs en tables chaudes (directement exploitable et requêtable) ou froides (exploitation payante, prix à la requête) selon leur importance.

2) Architecture mise en place pour le POC Sekoia

Pour le POC, il était nécessaire de faire coexister Sentinel et Sekoia pendant toute la durée de l'évaluation, sans interrompre la supervision existante. Cela s'est fait via la création d'un « Y » au niveau des concentrateurs vcosoclog-1 et vcosoclog-2 ([figure 5](#)) : les flux de logs continuaient à être envoyés normalement vers Log Analytics pour Sentinel, tout en étant dupliqués vers un troisième concentrateur, vcosoclog-3, mis en place spécifiquement pour le POC.

Le vcosoclog-3 jouait lui aussi un double rôle. En tant que concentrateur, il recevait les flux dupliqués depuis vcosoclog-1 et vcosoclog-2. En tant que collecteur pour Sekoia, il hébergeait un conteneur Docker faisant tourner l'agent d'ingestion Sekoia. Cet agent, équivalent fonctionnel de l'agent AMA utilisé pour envoyer ses logs vers Sentinel, récupérait les logs stockés localement sur le concentrateur et les transmettait à la plateforme Sekoia.io.

B) Architecture de la plateforme Sekoia

1) Les principales briques fonctionnelles

La plateforme Sekoia.io, telle que je l'ai utilisée pendant le POC, s'organisait autour de plusieurs espaces fonctionnels interconnectés.

L'espace des événements constituait le cœur de la plateforme. Il permettait de consulter l'ensemble des logs ingérés, tous maintenus en logs chauds. La consultation pouvait se faire via une interface graphique intuitive, en cliquant directement sur les valeurs de champs, ou via une barre de recherche. Un espace de requêtes dédié nommé « Querries » offrait des possibilités d'investigation plus poussées pour les analystes SOC avec les requêtes en SOL (Sekoia Operating Language défini précédemment) donnant notamment la possibilité d'implémenter des agrégations.

L'espace Intakes gérant l'enrôlement des sources de logs. C'est par cet espace que l'on configurait les nouvelles sources de données à ingérer dans la plateforme, via un catalogue de sources prédéfinies ou par ajout personnalisé via API.

L'espace des règles de détection permettait de consulter le catalogue de plus d'un millier de règles prédéfinies maintenues par Sekoia, ainsi que de créer et gérer des règles personnalisées.

L'espace IOC Collection regroupait les indicateurs de compromission (IOC), adresses IP, hash de fichiers, domaines malveillants, maintenus à jour par l'équipe de Threat Intelligence de Sekoia, avec la possibilité d'ajouter manuellement ses propres indicateurs.

Le tableau des alertes centralisait l'ensemble des alertes levées par les règles de détection et les IOC (trace technique (comme une adresse IP malveillante, un nom de domaine ou un hachage de fichier) découverte sur un réseau ou un système, qui prouve avec une forte probabilité qu'une intrusion ou une cyberattaque a eu lieu.), avec leur niveau de criticité, leur statut de traitement et les événements associés et plusieurs autres attributs, avec la possibilité de les gérer (les fermer avec un message « faux positif » ou « test », les marquer comme importante, ou même réglé...)

L'orchestrateur, accessible via l'espace des playbooks, constituait un avantage majeur de Sekoia par rapport à Sentinel. Il permettait de créer des automatisations en mode

graphique ou en JSON, déclenchées par des alertes ou des événements spécifiques. Le playbook le plus important dans notre contexte, créé par I-TRACING, assurait la redirection automatique des alertes vers leur propre orchestrateur XSOAR, en transmettant les attributs et champs des logs concernés pour permettre à I-TRACING d'orchestrer les actions de réponse de leur côté.

L'espace des communautés matérialisait la segmentation par filiale. Chaque communauté isolait entièrement ses données (sources, événements, alertes, orchestrateur...)

Enfin, la plateforme disposait d'un espace de gestion des utilisateurs et des rôles, ainsi que d'un espace de configuration des API. J'ai pu, entre autres, configurer le rôle par défaut attribué automatiquement à tout nouvel utilisateur rejoignant la plateforme (avec comme seule permission la vue sur les IOC, la création d'un rôle sans aucun droit n'étant pas possible), et tester les différentes API REST. J'ai d'ailleurs documenté l'utilisation de ces API, notamment pour la création de règles de détection et l'ajout d'IOC en télémétrie dans le wiki de l'entreprise.

La connexion à la plateforme était configurée exclusivement en SSO, s'intégrant ainsi dans la politique d'authentification unique de VINCI Concessions.

2) Règles de détection : de KQL à SIGMA

Le transfert des règles de détection de Sentinel vers Sekoia représentait une brique architecturale importante du projet. Sur Sentinel, les règles étaient écrites en KQL, un langage de requête propriétaire Microsoft. Sur Sekoia, le langage de détection standard est SIGMA, un format ouvert en YAML spécifiquement conçu pour la détection d'incidents de sécurité.

Le passage de KQL à SIGMA n'était pas une simple transposition syntaxique. Chaque règle devait être analysée pour en comprendre la logique de détection, puis réécrite en SIGMA en tenant compte des différences entre les deux approches. Certaines fonctionnalités KQL, comme les watchlists (listes de surveillance dynamiques), n'avaient pas d'équivalent direct en SIGMA et devaient être contournées ou simplifiées. La [figure 6](#) illustre cette différence à travers l'exemple d'une même règle de détection exprimée en KQL sur Sentinel puis en SIGMA sur Sekoia, mettant en évidence la différence de verbosité, de structure et de lisibilité entre les deux langages.

C) Architecture du projet GCP CCAI Platform

1) L'usine à projets FAST Project Factory

Le projet Contact Center AI Platform pour ViaCristais a été créé via l'usine à projets FAST Project Factory, un projet GitLab dédié à la création automatisée de projets sur Google Cloud Platform. Le principe repose sur l'Infrastructure as Code : l'ensemble des

paramètres du projet GCP est décrit dans un fichier de configuration YAML, et la pipeline CI/CD de GitLab se charge de provisionner le projet sur la plateforme GCP avec tous les paramètres spécifiés.

Le fichier YAML que j'ai configuré pour le projet CCAI définissait les éléments suivants :

- le compte de facturation à associer au projet
- les API à activer
- les rôles IAM spécifiques attribués aux membres de l'équipe de développement de ViaCristais (filiale de VINCI Highway),
- la définition du ou des buckets GCS destinés au stockage des tfstates (fichiers d'état Terraform)
- le choix du VPC (en l'occurrence le VPC partagé de VINCI Highways, puisque le projet était porté par cette entité et devait s'intégrer dans leur environnement réseau existant)
- la création des comptes de service associé au Workload Identity Federation.

2) Workload Identity Federation (WIF)

Le Workload Identity Federation était un élément architectural central du projet. Il permettait à la pipeline GitLab CI/CD de s'authentifier auprès de GCP sans utiliser de clé de compte de service statique, ce qui constitue une bonne pratique de sécurité en évitant la gestion et la rotation de secrets sensibles.

Le principe du WIF reposait sur la configuration de GitLab (hébergé en interne sous le domaine de VINCI Concessions) comme fournisseur d'identité auprès de GCP. Concrètement, lorsqu'une pipeline s'exécutait, GitLab émettait un jeton d'identité. GCP, configuré pour faire confiance à ce fournisseur d'identité, acceptait ce jeton et autorisait la pipeline à usurper un compte usurpateur de compte de service disposant des permissions nécessaires sur le projet GCP. Ce mécanisme d'usurpation de compte de service permettait de dissocier l'identité de la pipeline (authenticifiée via le WIF) des permissions effectives sur les ressources GCP (portées par le compte de service usurpé).

3) Pipeline de déploiement

Les déploiements de projets suivaient le processus standard de l'usine à projets, en plusieurs étapes d'environnement de développement jusqu'à l'environnement de production à travers des merge request de branche en branche avec revue par un pair. Une fois la pipeline de production exécutée avec succès, l'artifact était créé et stocké dans GCP (dans l'artifact registry), puis déployé créant ainsi le projet GCP sur la plateforme avec l'ensemble de ses paramètres, prêt à être utilisé par l'équipe de développement de ViaCristais.

7.Éléments importants du développement et difficultés rencontrées.

Cette section présente les éléments techniques marquants du développement de mes missions ainsi que les difficultés rencontrées, qu'elles soient techniques, personnelles ou organisationnelles. L'honnêteté sur ces difficultés me paraît essentielle car elles constituent autant des étapes d'apprentissage et reflètent la réalité d'un stage dans un environnement technique.

A) Difficultés liées à la montée en compétences initiale

1) Un départ en terrain inconnu

La difficulté la plus structurante de mon stage a été celle du point de départ. Issu d'une classe préparatoire scientifique et n'ayant intégré le cursus informatique qu'un an avant le stage, je suis arrivé chez VINCI Concessions avec des connaissances très limitées en cybersécurité et en infrastructure réseau. Les premières semaines ont été marquées par un décalage important entre le niveau technique des échanges au sein de l'équipe et mon propre niveau de compréhension.

Ce décalage s'est manifesté de manière particulièrement frappante lors des réunions avec I-TRACING, le prestataire SOC. Les discussions étaient accompagnées d'une multitude d'acronymes techniques (SIEM, SOAR, EDR, IOC, KQL, ECS...) qui m'étaient aussi étrangers que le syldave l'est au commun des mortels. Ma stratégie a été de noter systématiquement chaque terme incompris pendant les réunions, puis de me documenter sur leur signification et leur contexte d'utilisation. Au fil des semaines, les mêmes acronymes revenant régulièrement, j'ai progressivement construit un socle de compréhension qui m'a permis de suivre puis de participer aux échanges. Ce sont ces notes, accompagnées de la lecture de documentation technique et aux explications patientes de Xavier (mon tuteur de stage) lorsque la documentation ne suffisait pas, qui m'ont permis d'être opérationnel pour le début du POC Sekoia en décembre 2025.

2) L'échec du mini-projet GCP Mechanix

Comme évoqué dans les sections précédentes, le mini-projet GCP réalisé en début de stage s'est soldé par un échec. La difficulté n'était pas tant le développement Terraform que l'écosystème GitLab dans sa globalité. Je ne maîtrisais pas les concepts fondamentaux de la chaîne CI/CD : branches, environnements de développement et de production, pipelines, merge requests. Je ne comprenais pas la distinction entre le projet métier GCP et le projet GitLab qui le portait, ni l'articulation entre ces deux plateformes. Cette surcharge informationnelle m'a empêché de mener le projet à bien.

Cet échec, loin d'être un moment de découragement, a constitué un déclic. Il m'a confronté à mes lacunes de manière concrète et m'a motivé à approfondir ma

compréhension de ces outils au fil des semaines suivantes, par l'observation du travail de l'équipe et la lecture continue de documentation.

B) Difficultés techniques du projet SIEM

1) Le transfert des règles de détection : un exercice de traduction complexe

Le transfert des règles de détection de Sentinel (KQL) vers Sekoia (SIGMA) a constitué l'une des tâches techniques où j'ai passé le plus de temps durant mon stage. Plusieurs couches de complexité se superposaient.

La première difficulté résidait dans la compréhension des règles KQL existantes. La majorité des règles reposaient sur plusieurs tables relationnelles, reliées par des jointures, et intégraient des watchlists (fichiers externes sous forme de table) introduites par des instructions « let ». Pour chaque règle, il fallait d'abord comprendre le contenu et la raison d'être de chaque table et de chaque watchlist référencée, ce qui supposait un travail d'investigation préalable parfois long. La logique de détection n'était pas toujours évidente à saisir, les règles pouvant combiner des filtres complexes sur des champs variés.

La seconde difficulté, plus technique encore, portait sur la correspondance des attributs. Les champs utilisés dans les tables de Sentinel ne correspondaient pas à ceux de Sekoia, qui utilisait le schéma ECS (Elastic Common Schema). Il n'existait aucune documentation officielle permettant de « traduire » directement un attribut Sentinel en son équivalent ECS. Il fallait donc retrouver manuellement chaque correspondance. Si certaines traductions étaient relativement simples, par exemple, l'attribut « eventId » de Sentinel correspondait à « event.code » en ECS, d'autres étaient bien plus complexes. C'était notamment le cas des attributs de la table windowsEvent de Sentinel comme « eventData », qui est un tableau JSON encapsulant plusieurs champs, chacun correspondant à un ou plusieurs attributs ECS différents, et inversement. Ce travail de correspondance champ par champ était minutieux et chronophage.

La troisième difficulté concernait la gestion des watchlists. Sekoia ne disposait pas encore d'un équivalent fonctionnel des watchlists de Sentinel au moment du POC (cette fonctionnalité était annoncée pour quelques mois après la fin du POC). Il fallait donc identifier les éléments contenus dans les watchlists auxquels les règles faisaient référence et les intégrer directement dans le corps des règles SIGMA. Fort heureusement, les filtres appliqués sur les watchlists dans les règles de détection étaient assez restrictifs, ce qui limitait le nombre d'éléments à transférer manuellement.

2) Le débogage des règles : faux positifs et ajustements

Aucune des règles transférées n'a fonctionné comme attendu du premier coup. Chaque règle nécessitait une phase de test et d'ajustement itérative, parfois longue et laborieuse.

Le test consistait à simuler l'événement que la règle devait détecter, puis à vérifier sur la plateforme Sekoia si l'alerte se déclenchait correctement. Les simulations étaient réalisées depuis des machines virtuelles Linux sous VirtualBox, configurées en mode NAT et donc associées à la carte réseau de mon poste de travail. Ce choix était motivé par ma plus grande aisance sur Linux pour réaliser ces tests (scans de ports verticaux et horizontaux avec Nmap, tentatives de brute force sur le serveur RADIUS du WiFi de l'entreprise, entre autres). Du point de vue du SIEM, cela revenait au même que si les tests avaient été lancés depuis ma machine physique. Certaines règles n'ont cependant pas pu être testées, faute de permissions suffisantes, par exemple, une règle détectant l'ajout d'un compte dans un groupe à privilèges de l'Active Directory nécessitait des droits que je ne possédais pas.

Deux cas de débogage illustrent particulièrement la difficulté de cet exercice. Le premier concerne la règle « Suspicious rule added to a mailbox », basée sur des expressions régulières, qui devait générer une alerte lorsqu'un utilisateur ajoutait dans sa boîte de réception Outlook une règle correspondant à certains patterns suspects : règles de suppression automatique de certains types de mails, règles d'envoi automatique, règles dont le nom contenait des mots-clés déclencheurs comme « delete ». Cette règle générait une multitude de faux positifs, obligeant à reprendre et affiner les expressions régulières de manière itérative pour réduire le bruit tout en conservant la capacité de détection. Ce travail d'ajustement fin des regex a été extrêmement chronophage.

Le second cas est celui de la règle de détection de brute force, qui a elle aussi généré un volume important de faux positifs. L'ajustement des seuils de déclenchement et des conditions de filtrage a nécessité plusieurs itérations avant d'obtenir un comportement satisfaisant.

Une fois les règles fonctionnelles, je notais le temps de réponse entre la simulation de l'événement et la génération de l'alerte sur la plateforme Sekoia. Ce temps était généralement de quelques secondes, pouvant occasionnellement atteindre quelques minutes. Je réalisais ces mesures en parallèle sur Sentinel afin de disposer d'un comparatif des temps de réponse entre les deux SIEM. L'ensemble de ces résultats (statut fonctionnel ou non fonctionnel, temps de réponse, observations) était rigoureusement documenté dans GitLab.

3) La problématique de l'intégration avec XSOAR

Un point de blocage significatif a été la question de l'intégration des alertes Sekoia avec l'orchestrateur XSOAR d'I-TRACING. Le transfert des alertes avec leurs champs et attributs vers XSOAR était une condition nécessaire pour que I-TRACING puisse continuer à opérer le SOC depuis Sekoia. Cette problématique est restée en suspens pendant une période conséquente du POC. J'ai tenté de résoudre cette question lors de mon travail sur les API REST de Sekoia, mais sans succès. C'est finalement I-TRACING qui a trouvé une solution de leur côté. Il est intéressant de noter que la résolution de ce point de blocage

a coïncidé avec un changement d'attitude perceptible de la part d'I-TRACING : initialement réticents face à un changement de SIEM, ce qui est compréhensible pour un prestataire habitué à travailler quasi exclusivement avec Sentinel, ils se sont montrés nettement plus impliqués et motivés une fois cette intégration assurée.

4) L'interaction avec Sekoia

Malgré les difficultés inhérentes à tout POC, l'expérience avec la plateforme Sekoia a été globalement positive. La documentation était de bonne qualité et un Swagger était disponible pour les tests API, même si celui-ci incluait quelques défauts pour les requêtes POST. Lorsque des problèmes dépassaient le cadre de la documentation, notre contact chez Sekoia, Maxime Hugon, se montrait très réactif, confirmant presque instantanément la réception de nos questions et s'y penchant rapidement.

C) Difficultés du projet MDM

Le projet MDM n'a pas présenté de difficultés techniques majeures à proprement parler, mais plutôt des difficultés méthodologiques. La principale a été de mener une analyse de risque rigoureuse et une étude de marché exhaustive sur un domaine que je ne connaissais pas du tout au départ. Il a fallu que je me forme rapidement sur les problématiques de gestion de parc informatique, plus spécifiquement mobile, sur les fonctionnalités attendues d'un MDM, et sur les différences entre les écosystèmes iOS, Android et Windows en matière de gestion d'appareils.

Le travail de contact avec les éditeurs et d'organisation des présentations a également constitué un exercice formateur en termes de gestion de projet et de communication professionnelle, même si les délais de réponse n'ont pas posé de problème particulier en l'absence de date butoir formelle pour cette étude.

D) Une difficulté transformée en force : la curiosité comme moteur

Avec le recul, la difficulté la plus transversale de ce stage, le manque de connaissances initiales, s'est paradoxalement transformée en force motrice. N'ayant aucune base préétablie dans la plupart des domaines abordés, j'ai dû tout apprendre sur le terrain, ce qui m'a donné une vision très large des différents aspects de l'infrastructure et de la sécurité d'un système d'information. J'ai apprécié ce processus de documentation et d'apprentissage continu, qui me motivait à en découvrir toujours plus. L'absence de découragement face aux difficultés, y compris après l'échec du projet GCP initial, tient à cette curiosité naturelle qui a trouvé dans l'environnement technique de VINCI Concessions un terrain d'expression particulièrement stimulant.

8.Intégration, résultat des tests, comparaison avec les objectifs.

Cette section dresse le bilan des résultats obtenus pour chacune de mes missions, en les confrontant aux objectifs définis en début de projet. Elle permet de mesurer le chemin parcouru et d'évaluer, ce qui a été accompli et ce qui reste en suspens.

A) Résultats du POC Sekoia

1) Résultats des tests de détection

L'ensemble des règles de détection que j'ai entrepris de transférer de Sentinel vers Sekoia ont fini par fonctionner. Je ne passais à la règle suivante que lorsque la règle en cours était pleinement opérationnelle, testée et documentée. Ce choix, s'il a parfois ralenti l'avancement global, a garanti un taux de succès de 100 % sur les règles transférées.

Les mesures de temps de réponse comparées entre Sekoia et Sentinel se sont révélées globalement favorables à Sekoia. Dans la grande majorité des cas (plus de 80 % des tests réalisés), Sekoia détectait l'événement et générait l'alerte plus rapidement que Sentinel. Seule une minorité de tests, donnait un avantage à Sentinel. Ce résultat venait confirmer l'un des arguments avancés en faveur de Sekoia : la réactivité supérieure de la plateforme, portée notamment par son catalogue intégré d'indicateurs de compromission et son architecture de traitement des logs.

2) Bilan fonctionnel comparatif

Le document comparatif Sentinel versus Sekoia que j'ai rédigé pendant le POC a synthétisé les résultats de l'évaluation sur grands axes fonctionnels. Sur chacun de ces axes (vue et gestion des événements, déploiement des sources, orchestration, segmentation par filiale, langage de détection, catalogue d'IOC et catalogue de règles de détection), Sekoia présentait un avantage net par rapport à Sentinel. La plateforme offrait davantage de fonctionnalités intégrées, une plus grande souplesse d'utilisation, une meilleure adaptation au contexte décentralisé de VINCI Concessions et de ses filiales, et une réactivité supérieure.

À ces avantages fonctionnels s'ajoutaient les arguments de souveraineté numérique (société française, données hébergées en Europe chez OVH, absence d'exposition connue au Cloud Act) et les certifications de sécurité (ISO 27001, PCI-DSS niveau 1).

3) Bilan budgétaire

L'analyse budgétaire, après le travail itératif de chiffrage décrit dans la section 5, a abouti à une conclusion que le modèle de tarification à la volumétrie de Sekoia était moins cher que le coût de Sentinel, même après application du coefficient de conversion lié à la différence de format des logs entre les deux plateformes. Le modèle à l'asset, bien que

plus prévisible, s'avérait en revanche presque deux fois plus cher que Sentinel et n'a été retenu que pour quelques rares filiales dont le ratio consommation de logs par rapport à la taille était disproportionné.

La possibilité de coupler les deux modèles de tarification au sein d'une même plateforme a offert la flexibilité nécessaire pour optimiser le coût global par filiale. Au final, la solution Sekoia se positionnait comme moins chère que Sentinel à périmètre équivalent, tout en offrant des fonctionnalités supérieures, un résultat qui, au démarrage de l'étude, était loin d'être acquis.

4) Conclusion du POC et suite

À la fin du POC, fin janvier 2026, la conviction était unanime au sein de la DSI : Sekoia était la solution la plus adaptée aux besoins de VINCI Concessions. La solution était à la fois moins chère (sans même avoir encore négocié les tarifs) et plus efficace fonctionnellement.

Toutefois, la décision de migration n'a pas encore été officiellement actée à ce jour. La raison en est que Sekoia ne facture pas directement ses clients mais passe par l'intermédiaire du prestataire SOC. Les négociations commerciales sont donc en cours avec I-TRACING, qui doit proposer le tarif le plus avantageux pour cette solution. Depuis la fin du POC, c'est uniquement Sentinel qui est en production.

La présentation aux filiales a bien eu lieu. C'est le DSI, accompagné de Xavier pour les aspects techniques, qui l'ont portée. Mon travail (le document comparatif, l'analyse budgétaire et les éléments de présentation) a servi de base à cette communication.

B) Résultats du projet MDM

L'objectif du projet MDM était de produire un comparatif structuré des solutions du marché, appuyé sur une analyse de risque formalisée, afin d'éclairer la décision de la DSI. Cet objectif est en grande partie atteint.

L'analyse de risque selon la méthodologie EBIOS a été menée à bien, permettant d'identifier les événements redoutés, de calculer leur criticité, et d'en déduire les fonctionnalités indispensables pour le futur MDM. L'étude de marché a couvert une dizaine à une quinzaine de solutions au départ, filtrées progressivement jusqu'à cinq solutions finalistes (Matrix42 UEM, Hexnode, Fleet, ManageEngine et SOTI), avec des présentations organisées ou planifiées pour chacune d'entre elles. Le tableau comparatif consolidant l'ensemble des critères fonctionnels, techniques, de conformité et économiques constitue un livrable directement exploitable par la DSI.

L'étude est néanmoins toujours en cours au moment de la rédaction de ce rapport. Certaines présentations planifiées ne se sont pas encore déroulées, la dernière, avec Matrix42, étant prévue le 6 avril 2026, soit trois jours après la fin de mon stage. Deux solutions se distinguent à ce stade : Fleet, pour son caractère open source (malgré

quelques manques sur certaines fonctionnalités Android annoncés comme prochainement comblés), et ManageEngine, pour sa tarification remarquablement compétitive.

C) Résultats du projet GCP CCAI

L'objectif assigné, créer le projet métier GCP via l'usine à projets FAST Project Factory pour que l'équipe de développement de ViaCristais puisse démarrer l'implémentation de la plateforme Contact Center AI, a été partiellement atteint.

Le projet GCP a bien été créé sur la plateforme, incluant l'ensemble des paramètres configurés : les dix-sept API activées, les rôles IAM, les buckets pour les tfstates, le VPC partagé de VINCI Highways, les comptes de service et le Workload Identity Federation. Ce résultat est à mettre en perspective avec l'échec du mini-projet GCP Mechanix en début de stage : en l'espace de quelques mois, j'étais passé d'une incompréhension totale de l'écosystème GitLab CI/CD et GCP à la capacité de créer un projet complet de manière quasi-autonome.

Toutefois, l'équipe de développement de ViaCristais n'a pas encore commencé à travailler sur le projet au moment de la rédaction de ce rapport. Le projet métier GCP est en place, mais le projet GitLab d'implémentation n'a pas encore été initié de leur côté.

D) Résultats des missions annexes

L'étude de faisabilité QGIS/PostgreSQL, bien qu'elle se soit conclue sans solution pleinement satisfaisante, a néanmoins produit un livrable utile : une recommandation pour la création de comptes PostgreSQL individuels, améliorant la traçabilité par rapport au compte partagé existant. Les pistes explorées (Lizmap, GeoServer) et les raisons de leur inadéquation ont été documentées, ce qui permettra à l'équipe d'éviter de réinvestiguer ces options à l'avenir.

E) Bilan global : comparaison avec les objectifs

En synthèse, les paragraphes ci-dessous confrontent les objectifs assignés aux résultats obtenus :

Pour le projet SIEM, le transfert des règles de détection KQL vers SIGMA a été réalisé avec un taux de succès de 100 % sur les règles entreprises, chacune ayant été testée et documentée. L'analyse budgétaire comparative entre les offres Sekoia et Sentinel a été menée à bien, aboutissant à la mise en évidence d'un avantage tarifaire pour Sekoia à la volumétrie. Le document comparatif Sentinel versus Sekoia a été rédigé et a servi de support à la présentation aux filiales. La documentation des API REST de Sekoia a été produite, avec un succès majoritaire sur les différents cas d'usage testés, même si certains points comme l'ajout d'IOC en télémétrie via un fichier tabulaire n'ont pas pu être menés à bien du fait de limitations du Swagger de Sekoia sur les requêtes POST.

Pour le projet MDM, l'analyse de risque EBIOS et l'étude de marché comparative ont été réalisées. Le comparatif est livré mais l'étude se poursuit au-delà de mon stage pour la recommandation finale.

Pour le projet GCP CCAI, le projet métier a été créé avec succès via l'usine à projets, mais l'implémentation par ViaCristais n'a pas encore débuté.

Sur le plan des objectifs personnels, la montée en compétences, qui constituait mon objectif premier, a été largement atteinte. En 5 mois, j'ai acquis des bases dans des domaines aussi variés que l'architecture d'un SI d'entreprise, le fonctionnement d'un SIEM et d'un SOAR, les langages KQL et SIGMA, l'Infrastructure as Code avec Terraform et les pipelines GitLab CI/CD, la méthodologie d'analyse de risque EBIOS, les principes du SSO et de la PKI, et la gestion de projet dans un contexte multi-parties prenantes.

9.Observation des pratiques managériales

Au-delà des missions techniques, mon stage chez VINCI Concessions a été l'occasion d'observer de près le fonctionnement managérial d'une DSI au sein d'un grand groupe international. Le DSI consacrait régulièrement du temps à m'expliquer sa vision de l'organisation et du management, lors de pauses café, de déjeuners ou d'échanges dans son bureau. Ces moments, bien que informels, ont constitué un volet formateur de mon stage.

A) La philosophie managériale du DSI

1) La technique au service de l'organisation

Un des principes fondamentaux portés par le DSI est que la technique doit être au service de l'organisation, et non l'inverse. Pour lui, les deux piliers d'une DSI performante sont la maîtrise technique et la qualité de l'organisation du travail, et la première doit toujours servir la seconde. La technique doit améliorer l'organisation, la simplifier, l'automatiser. Lorsque l'organisation se met à s'adapter aux contraintes d'un outil technique plutôt que de choisir un outil adapté à ses besoins organisationnels, c'est le signe d'un déséquilibre. Cette philosophie se retrouvait concrètement dans plusieurs choix de la DSI que j'ai pu observer pendant mon stage : le choix de migrer vers Sekoia plutôt que de rester sur Sentinel répondait à un besoin organisationnel (segmentation par filiale, autonomie vis-à-vis de Microsoft) avant d'être un choix technique ; de même, le choix de GitLab comme outil central de traçabilité répondait à un besoin d'organisation et de rigueur dans le suivi des modifications.

2) Le respect des règles par le chef

Un autre principe auquel le DSI tenait particulièrement était celui de l'exemplarité du dirigeant vis-à-vis des règles d'organisation. Pour lui, le chef ne doit en aucun cas échapper aux règles qu'il impose à son équipe, bien au contraire. Si le DSI demandait un service à un collaborateur, celui-ci devait lui répondre de créer d'abord un ticket, exactement comme le ferait n'importe quel autre demandeur. Cette règle, appliquée avec une bonne dose d'humour, était régulièrement mise en scène par le DSI lui-même : il lui arrivait de demander un service informellement, puis de reprendre la personne qui acceptait de le faire sans avoir exigé le passage par un ticket. L'objectif n'était pas de piéger les collaborateurs, mais de rappeler, de manière légère et récurrente, un principe fondamental : la traçabilité et l'organisation passent avant la commodité, y compris pour la personne la plus haut placée dans la hiérarchie.

3) L'importance des relations humaines et de la connaissance de l'équipe

Le DSI insistait également sur l'importance de connaître le travail de ses collègues et de savoir vers qui se tourner lorsqu'un problème se présentait. Il soulignait aussi un aspect qui peut sembler anodin mais qui s'avère précieux au quotidien : connaître les personnes par leur nom. D'une part, une personne constatant que l'on connaît son nom a naturellement une meilleure image de son interlocuteur, ce qui facilite les échanges et la collaboration. D'autre part, dans une organisation où les noms circulent constamment dans les mails, les réunions et les discussions informelles, savoir immédiatement de qui l'on parle permet de mieux comprendre les enjeux et de savoir vers qui rediriger certaines demandes. Ces conseils, que le DSI prenait le temps de me transmettre, dépassaient le cadre strict de l'informatique et relevaient d'une vision plus large du savoir-être en entreprise.

4) La flexibilité encadrée

La DSI fonctionnait avec une grande flexibilité sur les horaires de travail. Il n'exigeait de personne des horaires strictes, à une exception près : l'équipe du support informatique (SIEL), qui devait assurer une présence dès 8h20 chaque matin. Cette exception n'était pas arbitraire mais répondait à un impératif organisationnel : les utilisateurs devaient pouvoir compter sur une assistance dès le début de leur journée de travail. Pour le reste de l'équipe, c'est la confiance et la responsabilisation qui primaient, avec une évaluation fondée sur les résultats et l'engagement plutôt que sur la présence physique.

B) L'encadrement au sein de l'équipe infrastructure

1) Un management informel et efficace

Le management au quotidien au sein de l'équipe infrastructure se caractérisait par son informalité. Il n'y avait pas de réunions ritualisées de type daily ou weekly stand-up. Les réunions formelles n'étaient organisées que lorsque les personnes nécessaires n'étaient

pas présentes au siège ou étaient en télétravail. Le reste du temps, les échanges se faisaient de bureau en bureau, de manière spontanée et directe. Cette organisation fluide était rendue possible par la taille réduite de l'équipe et par la proximité physique des bureaux.

L'atmosphère au sein de l'équipe était remarquablement unie et détendue. Un détail anecdotique mais révélateur : les salutations du matin ne se faisaient pas avec des poignées de mains formelles mais avec les poings, témoignant d'une convivialité et d'un esprit d'équipe qui dépassaient le cadre strictement professionnel. Cette ambiance contribuait à rendre les échanges techniques plus fluides et à faciliter les demandes d'aide lorsque l'on rencontrait un blocage.

2) L'encadrement par Xavier Morand

Xavier Morand, qui m'encadrait au quotidien, avait un style de management que je qualifierais d'adaptatif. Il parvenait à combiner autonomie et suivi de manière très naturelle. Pour les tâches dont il estimait que je disposais des compétences et des informations nécessaires, il me laissait en totale autonomie, me faisant confiance dans ma capacité à mener le travail à bien. Pour les tâches plus complexes ou nouvelles pour moi, il prenait régulièrement des nouvelles de mon avancement pour s'assurer que je n'étais pas bloqué et pour intervenir au bon moment si nécessaire. Cet équilibre entre confiance et vigilance m'a permis de progresser rapidement tout en me sentant soutenu dans les moments de difficulté.

Il s'assurait également de mon intégration dans les différentes missions qui m'étaient confiées, veillant à ce que j'aie toujours le contexte nécessaire pour comprendre le « pourquoi » de ce que je faisais et pas seulement le « comment ».

C) Le recours aux prestataires externes

Une observation importante concerne la composition de l'équipe DSI. La majorité des collaborateurs étaient des prestataires externes, et l'équipe du support informatique (SIEL) était même composée à 100 % d'externes. La raison de ce choix, qui m'a été expliquée, est d'ordre stratégique : il est plus simple de réduire les effectifs externes dans les périodes difficiles. L'illustration la plus frappante est celle de la crise du Covid-19, durant laquelle VINCI Concessions a perdu des milliards sur les concessions aéroportuaires et a dû ajuster ses effectifs en conséquence. Le recours aux prestataires offre une flexibilité que les contrats internes ne permettent pas.

Ce qui m'a surpris positivement, c'est la transparence du traitement entre internes et externes au quotidien. J'ai mis plusieurs semaines avant de distinguer les internes des externes, et c'est uniquement parce que j'avais fait des recherches de mon côté. Au quotidien, il n'y avait aucune différence de traitement, d'accès à l'information ou de considération dans les échanges. La seule différence perceptible était que, les

prestataires ne bénéficiant pas de la subvention cantine, ils déjeunaient moins souvent avec le reste de l'équipe, même si certains le faisaient tout de même.

D) Enseignements personnels

L'observation de ces pratiques managériales m'a apporté une vision concrète de ce que peut être le management dans une DSI d'un grand groupe. Plusieurs enseignements me semblent particulièrement précieux pour ma future carrière : l'importance de la traçabilité et de l'organisation comme fondements de la maîtrise d'un système d'information, la nécessité pour un dirigeant de s'appliquer à lui-même les règles qu'il impose, la valeur d'un encadrement adaptatif qui sait doser autonomie et accompagnement en fonction du niveau de la personne encadrée, et l'importance de cultiver les relations humaines et la connaissance de son environnement professionnel au-delà des seules compétences techniques. Ces observations viennent compléter les apprentissages techniques de mon stage et constituent, à leur manière, une excellente formation.

10.Conclusion

A) Devenir du travail et développements ultérieurs

Les travaux réalisés durant ce stage ne constituent pas une fin en soi, mais s'inscrivent dans des dynamiques de long terme au sein de la DSI de VINCI Concessions.

Concernant le projet SIEM, le POC Sekoia a permis de démontrer de manière convaincante la supériorité de cette solution par rapport à Microsoft Sentinel, tant sur le plan fonctionnel qu'économique. Au moment de la rédaction de ce rapport, la migration définitive vers Sekoia n'a pas encore été officiellement actée, les négociations commerciales avec I-TRACING étant toujours en cours. Toutefois, le travail de fond réalisé pendant le POC (le transfert et la validation des règles de détection, l'analyse budgétaire comparative, le document de synthèse Sentinel versus Sekoia, la documentation des API REST) constituera le socle sur lequel s'appuiera l'équipe pour la phase de déploiement en production. Plusieurs développements ultérieurs sont envisageables : l'extension du périmètre de détection avec de nouvelles règles SIGMA exploitant le catalogue intégré de Sekoia, l'enrichissement des playbooks d'automatisation dans l'orchestrateur, le déploiement de la segmentation par communautés pour les filiales souhaitant accéder à leurs propres données de sécurité, et la mise en place des watchlists une fois la fonctionnalité équivalente disponible chez Sekoia, ce qui simplifiera la gestion des règles de détection transférées.

Concernant le projet MDM, l'étude de marché que j'ai réalisée sera poursuivie par l'équipe après mon départ. Les dernières présentations d'éditeurs sont planifiées, et la recommandation finale devra être formulée en tenant compte des résultats de ces

démonstrations. Le tableau comparatif, l'analyse de risque EBIOS et les critères d'évaluation que j'ai formalisés en concertation avec le RSSI et l'équipe du support informatique constituent un cadre structuré directement exploitable pour la prise de décision. Le choix du MDM, une fois arrêté, ouvrira un nouveau projet de déploiement et d'intégration dans l'infrastructure existante, incluant notamment la configuration du SSO via Keycloak et la définition des politiques de gestion par profil d'utilisateur.

Concernant le projet GCP CCAI, le projet métier a été créé avec succès sur la plateforme Google Cloud. L'étape suivante, qui ne dépend plus de l'équipe infrastructure mais de l'équipe de développement de ViaCristais, est l'initialisation du projet GitLab d'implémentation et le développement de la solution de centre d'appels basée sur l'IA conversationnelle de Gemini. Le socle technique que j'ai mis en place (API activées, IAM configuré, VPC rattaché et le WIF pour l'accès aux comptes de service) permettra aux développeurs de démarrer leur travail sans avoir à se préoccuper de l'infrastructure sous-jacente, ce qui est précisément l'objectif de l'approche Infrastructure as Code.

B) Bilan du stage

Ce stage de vingt semaines au sein de la DSI de VINCI Concessions a été une expérience d'une grande richesse. Le bilan que j'en tire est structuré autour de trois dimensions : technique, humaine et professionnelle.

Sur le plan technique, la progression a été considérable. En arrivant avec des connaissances très limitées en cybersécurité et en infrastructure, j'ai acquis en 5 mois des bases dans des domaines variés. Le projet SIEM m'a formé au fonctionnement d'un SIEM et d'un SOAR, aux langages de détection KQL et SIGMA, à la gestion des logs et à la compréhension des architectures de supervision de sécurité. Le projet MDM m'a initié à la méthodologie d'analyse de risque EBIOS, à la conduite d'une étude de marché structurée et à la problématique de la gestion de flotte mobile. Le projet GCP CCAI m'a permis de maîtriser les bases de l'Infrastructure as Code avec Terraform, de comprendre le fonctionnement des pipelines CI/CD GitLab et de me familiariser avec l'écosystème Google Cloud Platform, incluant des concepts avancés comme le Workload Identity Federation. Au-delà de ces domaines spécifiques, j'ai développé une compréhension globale de ce qu'est le système d'information d'un grand groupe international : son architecture physique et logique, ses mécanismes d'authentification, sa gestion des risques, sa relation avec les filiales et ses prestataires.

Sur le plan humain, ce stage m'a offert une immersion dans le fonctionnement d'un grand groupe que la formation académique ne peut pas reproduire. J'ai découvert la réalité des interactions entre une DSI centrale et ses filiales internationales et la complexité des processus de décision impliquant de multiples parties prenantes (DSI, RSSI, direction technique, pôle achats, prestataires SOC, éditeurs de solutions). Les échanges avec le DSI sur sa vision du management, les discussions techniques avec Xavier Morand et Loïc

Barge, les réunions avec I-TRACING et Sekoia, les présentations des éditeurs MDM : chacune de ces interactions a contribué à élargir ma vision de ce qu'est le métier d'ingénieur en systèmes d'information. J'ai compris que la compétence technique, aussi importante soit-elle, ne suffit pas. La capacité à communiquer, à structurer une argumentation (comme dans le comparatif Sentinel/Sekoia), à comprendre les contraintes budgétaires et organisationnelles, et à travailler avec des interlocuteurs aux profils très différents sont des compétences tout aussi importantes.

C) Apport et enseignement personnel

Sur le plan personnel, ce stage a confirmé et précisé mon appétence pour les métiers à l'intersection de la cybersécurité, de l'infrastructure et du cloud. J'ai particulièrement apprécié la diversité des missions. Cette variété, loin d'être déstabilisante, a été pour moi une source de stimulation permanente.

J'ai également découvert que j'appréciais le processus d'apprentissage en lui-même. Arriver chaque jour face à des concepts que je ne maîtrisais pas et repartir le soir en les ayant compris, ne serait-ce que partiellement, a été une source de satisfaction constante. L'absence de découragement face aux difficultés, m'a confirmé que la curiosité et la persévérance sont des qualités sur lesquelles je peux m'appuyer pour ma future carrière.

Parmi les enseignements que je retiens de ce stage, plusieurs dépassent le cadre technique. L'importance de la traçabilité et de la documentation, martelée par le DSI et incarnée dans l'utilisation de GitLab, est un principe que j'appliquerai dans tous mes futurs projets. La rigueur de l'analyse de risque, apprise à travers la méthodologie EBIOS pour le MDM, m'a montré qu'une décision technique éclairée repose sur une démarche structurée et non sur l'intuition. Enfin, l'observation des pratiques managériales m'a sensibilisé à des dimensions que ma formation d'ingénieur aborde peu : l'exemplarité du dirigeant, l'importance de connaître ses collègues et leur travail, et la valeur d'un encadrement qui sait doser autonomie et accompagnement.

D) Place de ce stage dans le projet professionnel

Ce stage s'inscrit comme une étape fondatrice dans mon parcours professionnel. Il m'a permis de transformer des connaissances académiques très récentes en compétences appliquées, dans un environnement industriel exigeant. Il m'a surtout permis de confirmer mon orientation vers un profil polyvalent, à la croisée de la cybersécurité, de l'infrastructure et du cloud, trois domaines que j'ai eu la chance de toucher simultanément pendant ces 5 mois.

L'année prochaine constituera ma dernière année du cycle ingénieur à l'Efrei, et je souhaite la réaliser en alternance, si possible au sein de VINCI Concessions. Poursuivre au sein de la même équipe me permettrait de capitaliser sur les connaissances acquises

pendant ce stage, d'approfondir les projets que j'ai initiés, et de monter en compétences sur des sujets plus avancés avec un niveau de maturité technique supérieur à celui de mon arrivée

L'expérience au sein d'une DSI d'un grand groupe, où l'informatique est une fonction support au service d'activités métiers concrètes (aéroports, autoroutes, stades, voies ferrées) m'a montré que la technique prend tout son sens lorsqu'elle répond à un besoin réel. C'est dans cette logique que je souhaite construire ma carrière d'ingénieur.

11.Bibliographie

Cliquer sur le titre de chaque figure pour se déplacer à l'endroit où elle est évoquée

Figure 1 - Organigramme du groupe VINCI incluant les chiffres d'affaires de ses filiales et la répartition entre les principaux métiers en 2025
Ilyan Bendahmane 2026

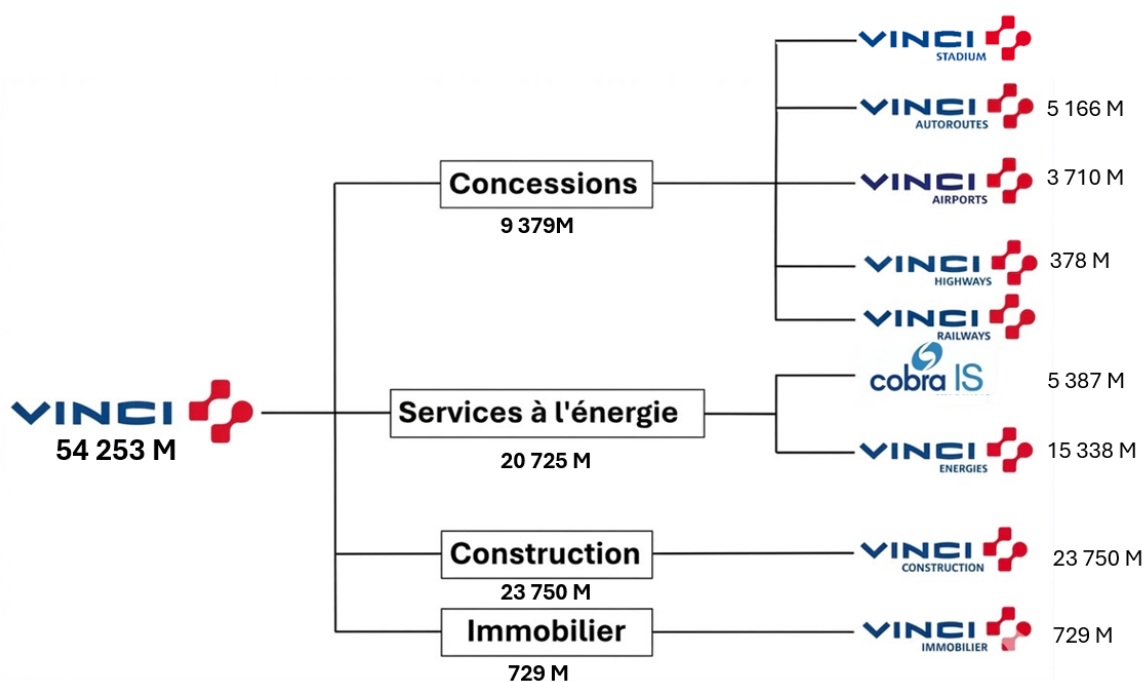


Figure 2 - Organigramme de la DSI de VINCI Concessions
VINCI Concession 2025

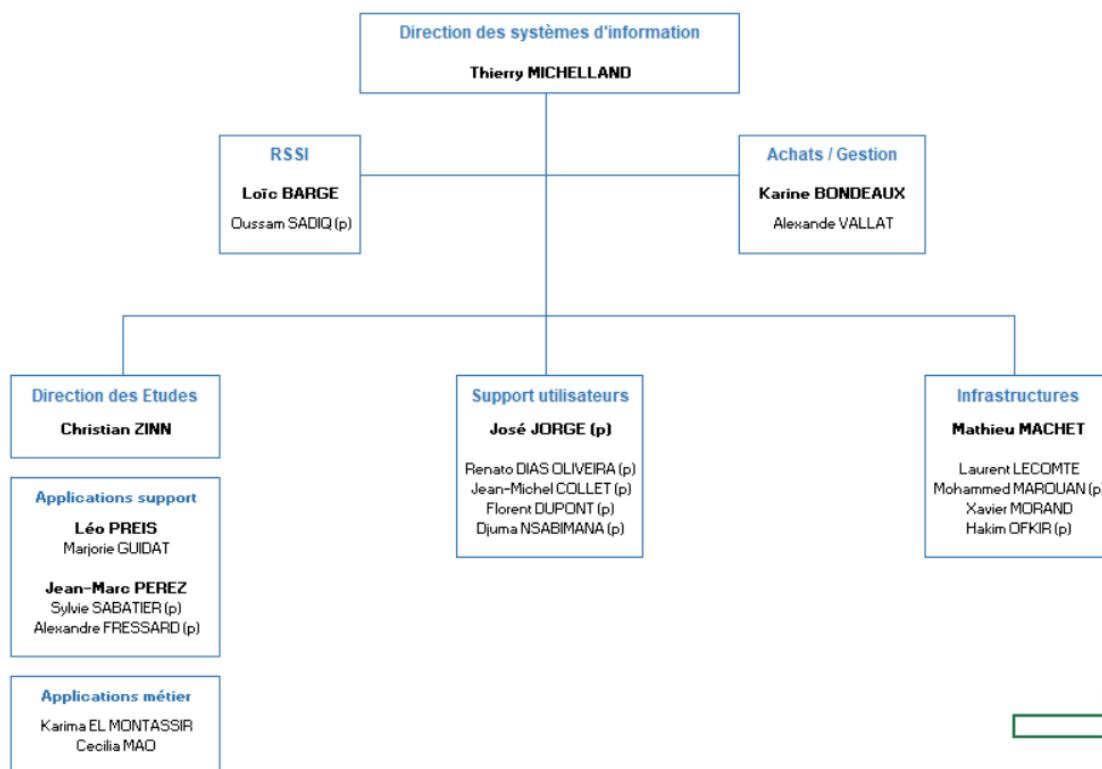
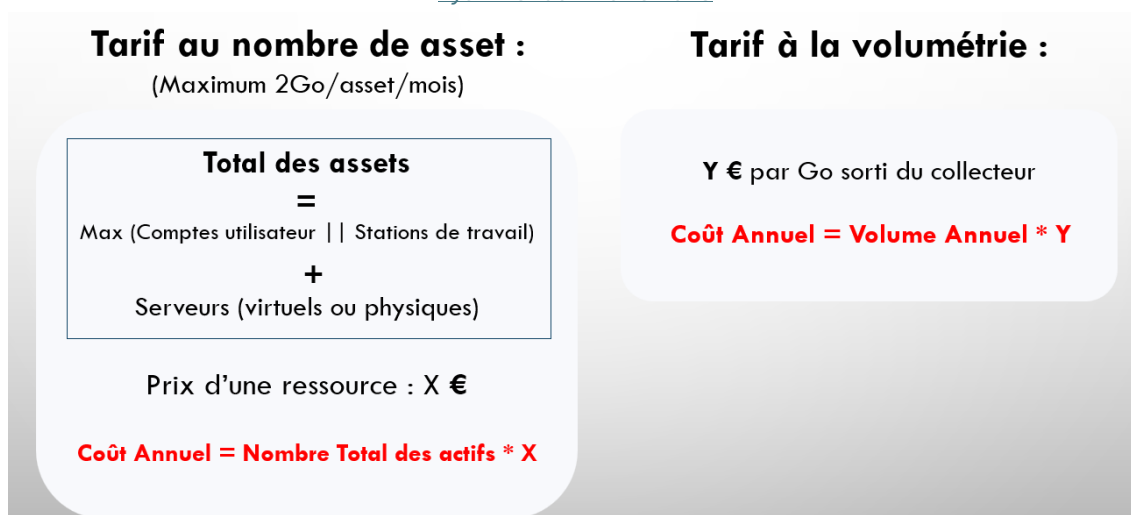
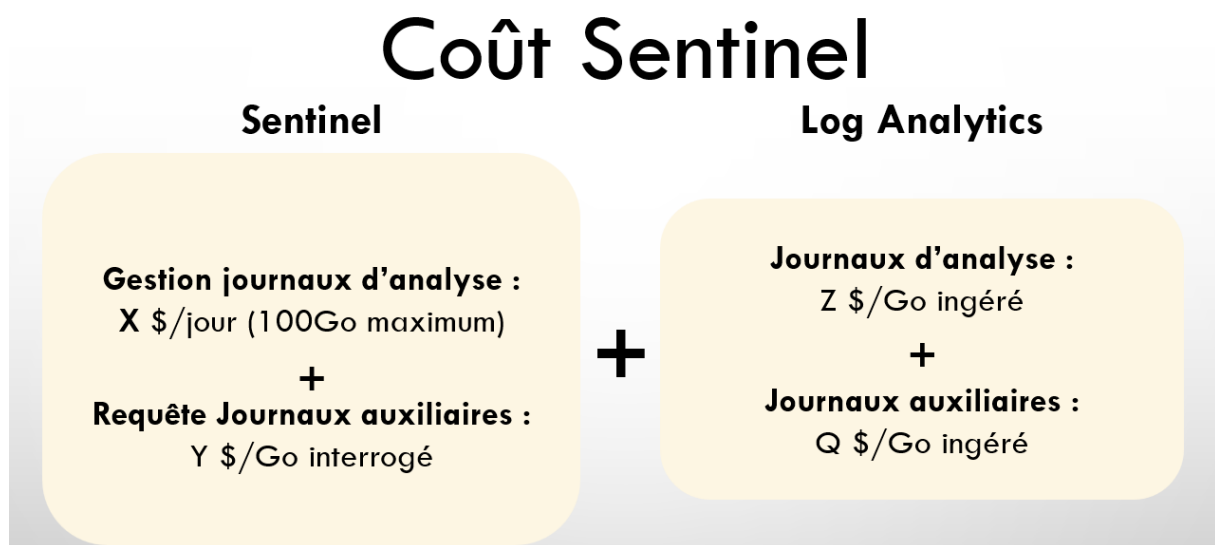


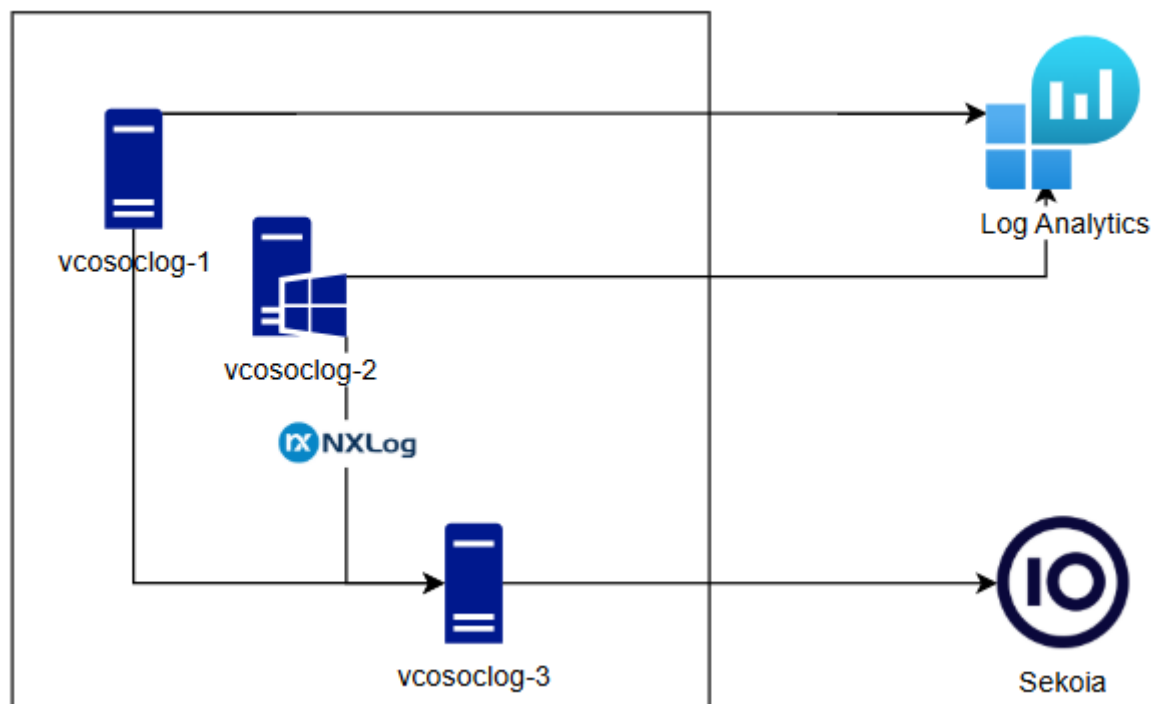
Figure 3 - Tarification de Sekoia, basé sur les ressources ou le volume de log
Ilyan Bendahmane 2025



*Figure 4 - Tarification de Sekoia, basé sur les ressources ou le volume de log
Ilyan Bendahmane 2025*



*Figure 5 – Architecture mise en place pour le POC Sekoia
Xavier Morand, VINCI Concessions, 2026*



*Figure 6 - Exemple visuel de verbosité des 2 langages de détection pour une règle de scan vertical de port
Ilyan Bendahmane, 2025*

Exemple d'une règle initialement créée par I-Tracing en KQL sur Sentinel (~ 4400 caractères) :

```
let scope_assignment = _GetWatchlist('VINCI-SOC-Scope-Assignment');
let PortScan_WL = _GetWatchlist('VINCI-SOC-WL_PortScan');
let Hostname_WL = _GetWatchlist('VINCI-SOC-Temporary_WL_AP')
    | where isnotempty(hostname)
    | project hostname
    | summarize make_list(hostname);
let IPranges_WL = PortScan_WL
    | where isempty(SourcePort) and isempty(DestinationIP) and isempty(DestinationPort)
    | project SourceIP
    | summarize make_list(SourceIP);
let SrcIP_WL = PortScan_WL
    | where isempty(SourcePort) and isempty(DestinationIP) and isempty(DestinationPort)
    | project SourceIP;
let SrcPort_WL = PortScan_WL
    | where isnotempty(SourcePort)
        and isempty(DestinationIP)
        and isempty(DestinationPort)
        and SourceIP in ("*", "0.0.0.0/32")
    | project toint(SourcePort);
let SrcIP_DestPort_WL = PortScan_WL
    | where isempty(SourcePort) and isempty(DestinationIP) and isnotempty(DestinationPort)
    | project SourceIP, toint(DestinationPort);
let SrcPort_DestPort_WL = PortScan_WL
    | where isnotempty(SourcePort)
        and isnotempty(DestinationPort)
        and SourceIP in ("*", "0.0.0.0/32")
    | project toint(SourcePort), toint(DestinationPort);
let DestIP_WL = PortScan_WL
    | where isempty(SourcePort)
        and isempty(DestinationPort)
        and SourceIP in ("*", "0.0.0.0/32")
    | project DestinationIP;
let Src_IP_DestIP_WL = PortScan_WL
    | where isempty(SourcePort)
        and isempty(DestinationPort)
        and SourceIP !in ("*", "0.0.0.0/32")
    | project DestinationIP, SourceIP;
CommonSecurityLog
| where (ipv4_is_private(SourceIP) or ipv6_is_in_range(SourceIP, "fc00::/7"))
    and (ipv4_is_private(DestinationIP) or ipv6_is_in_range(DestinationIP, "fc00::/7"))
    and DestinationPort in (20, 21, 22, 23, 25, 88, 135, 137, 139, 161, 162, 389, 445, 636, 1433, 1521, 3306, 3389, 5432, 5601,
5985, 5986, 9200)
| where not(DeviceInboundInterface has_any("Wifi_Nomosphere", "guest", "Guest", "wifi_invites", "PUBLIC-WIFI", "vlan3",
"SID-FreeWLAN"))
| parse _ResourceId with * "machines/" FWD_Machine
| lookup scope_assignment on $left.FWD_Machine == $right.Machine
| extend VINCI_scope = strcat(VINCI_Pole, "$scope_division:", VINCI_Division, "$scope:", VINCI_Entite, "$")
| where SourcePort !in (toscalar(whiteliste
    | where type == 'wildcard' and alert == 'FRW-003'
    | project field_wildcard
    | summarize make_list(field_wildcard)))
| where ((ipv4_is_in_any_range(DestinationIP, toscalar(whiteliste
    | where type == 'IP-Dest' and alert == 'FRW-003'
    | project SearchKey
    | summarize make_list(SearchKey))) == false))
and
```

```

((ipv4_is_in_any_range(SourceIP, toscalar(whiteliste
| where type == 'IP-Src' and alert == 'FRW-003'
| project SearchKey
| summarize make_list(SearchKey))) == false)
    and (ipv6_is_in_any_range(SourceIP, toscalar(whiteliste
| where type == 'IP-Src' and alert == 'FRW-003'
| project SearchKey
| summarize make_list(SearchKey))) == false))
| where ipv4_is_in_any_range(SourceIP, toscalar(IPranges_WL)) == false
| where Computer !in (toscalar(Hostname_WL))
| join kind=leftanti SrcIP_WL on SourceIP
| join kind=leftanti SrcPort_WL on SourcePort
| join kind=leftanti SrcIP_DestPort_WL on SourceIP, DestinationPort
| join kind=leftanti SrcPort_DestPort_WL on SourcePort, DestinationPort
| join kind=leftanti DestIP_WL on DestinationIP
| join kind=leftanti Src_IP_DestIP_WL on SourceIP, DestinationIP
| summarize
    EarliestTime = min(TimeGenerated),
    LatestTime=max(TimeGenerated),
    Action=make_set(DeviceAction),
    NbDestPort = dcount(DestinationPort),
    List_DestPort = make_set(DestinationPort, 30),
    FrwInboundInterface = make_set(DeviceInboundInterface),
    FrwOutboundInterface = make_set(DeviceOutboundInterface),
    count()
    by
    VINCI_scope,
    FWD_Machine,
    Computer,
    SourceIP,
    DestinationIP,
    bin(TimeGenerated, 15m)
| where NbDestPort > 6
| extend xsoar_fields = strcat("EarliestTimeUTC:", EarliestTime, "LatestTimeUTC:", LatestTime, "saction:", Action,
"$dest_port_nb:", NbDestPort, "$dest_port:", List_DestPort, "$inbound_interface:", FrwInboundInterface,
"$outbound_interface:", FrwOutboundInterface, "$fwd_machine:", FWD_Machine, "$host:", Computer, "$dest_ip:",
DestinationIP, "$scope_pole:", VINCI_scope)

```

Exemple d'une règle transférée en SIGMA sur Sekoia par mes soins (~ 1700 caractères) :

```

name: filtre_paramètres
detection:
  selection1:
    source.ip|cidr:
      - '10.0.0.0/8'
      - '172.16.0.0/12'
      - '192.168.0.0/16'
      - 'fc00::/7'
    destination.ip|cidr:
      - '10.0.0.0/8'
      - '172.16.0.0/12'
      - '192.168.0.0/16'
      - 'fc00::/7'
    destination.port:
      - 20
      - 21
      - 22
      - 23
      - 25
      - 88
      - 135
      - 137

```

```
- 139
- 161
- 162
- 389
- 445
- 636
- 1433
- 1521
- 3306
- 3389
- 5432
- 5601
- 5985
- 5986
- 9200
selection2:
observer.ingress.interface.name|contains:
- 'Wifi_Nomosphere'
- 'guest'
- 'Guest'
- 'wifi_invites'
- 'PUBLIC-WIFI'
- 'vlan3'
- 'SID-FreeWLAN'
condition: selection1 and not selection2
---
name: filtre_champs_1
action: correlation
type: value_count
rule: filtre_paramètres
group-by:
- log.hostname
- destination.ip
- source.ip
field: destination.port
timespan: 15m
condition:
gt: 6
falsepositives :
- "172.29.20.0/23"
- "10.100.3.50"
- "10.20.2.36"
- "192.168.20.10"
- "10.19.55.35"
- "172.16.198.155"
- "172.28.20.0/23"
- "172.24.20.0/23"
- "172.21.20.0/23"
- "192.168.113.36"
- "10.4.133.46"
- "172.16.106.0/24"
- "172.22.20.0/23"
- "192.168.20.20"
- "10.1.1.10"
- "10.20.3.74"
- "192.168.1.203"
- "10.1.1.12"
- "172.23.20.0/23"
- "172.16.201.31"
- "172.27.20.0/23"
- "172.25.20.0/23"
- "192.168.202.0/24"
- "172.26.20.0/23"
```


- "192.168.145.1"
- "172.17.9.201"
- "172.20.20.0/23"